

AZURE SECURITY SERVICES

A Deep Technical Reference Guide

Mapped to the NIST Cybersecurity Framework (CSF) 2.0

Govern • Identify • Protect • Detect • Respond • Recover

*Architecture patterns, configuration depth, and real-world implementation guidance
for multi-subscription, multi-cloud, multi-tenant SaaS environments*

Companion reference to the AWS Security Services Deep Technical Reference

Table of Contents

Table of Contents	2
Purpose & Framework Note	5
How to use this document	5
Key Structural Differences from the AWS Reference	5
1. GOVERN	7
1.1 Azure Management Groups, Subscriptions & Resource Hierarchy	7
Mechanism	7
Resource Hierarchy and RBAC Inheritance	7
1.2 Azure Policy & Initiatives	8
Mechanism	8
Alternatives / Complements	9
1.3 Microsoft Purview Compliance Manager	10
Mechanism	10
1.4 Microsoft Entra Permissions Management — Governance Angle	11
1.5 Govern Function — Summary Table	11
2. IDENTIFY	13
2.1 Microsoft Defender for Cloud — CSPM & Posture	13
Mechanism	13
Where it falls short	14
Alternatives / Complements	14
2.2 Microsoft Defender Vulnerability Management	14
Mechanism	14
Alternatives	15
2.3 Microsoft Purview — Data Discovery & Classification	15
Mechanism	15
Limitations and alternatives	16
2.4 Azure Resource Graph	16
Alternatives	17
2.5 Entra Permissions Management — Exposure Findings	17
2.6 Identify Function — Summary Table	18
3. PROTECT	20
3.1 Microsoft Entra ID (Azure AD)	20
Core Mechanism	20
ABAC and Multi-Tenant Isolation in Azure RBAC	20
Where it falls short / common failure modes	21
Alternatives / Complements	21

3.2 Entra Conditional Access	21
Mechanism	22
3.3 Entra ID Governance — PIM, Access Reviews & Entitlement Management	23
Privileged Identity Management (PIM)	23
Access Reviews and Entitlement Management	23
Alternatives	24
3.4 Azure Key Vault & Managed HSM	24
Mechanism	24
CMK/CMEK Pattern for Multi-Tenant Isolation	25
Alternatives	26
3.5 Azure Web Application Firewall (WAF)	26
Mechanism	26
Alternatives	27
3.6 Azure DDoS Protection	27
3.7 Azure Firewall & Firewall Manager	28
Mechanism	28
3.8 Network Security Groups, Application Security Groups & VNet Architecture	29
3.9 Azure Front Door & Azure CDN	30
Alternatives	31
3.10 Azure DNS & Private DNS	32
Alternatives	32
3.11 Azure Application Gateway	33
3.12 Azure Bastion	33
3.13 Microsoft Defender for Containers / AKS Security	34
Mechanism	34
Alternatives	35
3.14 Azure Storage Account Security	35
3.16 Protect Function — Summary Table	37
4. DETECT	38
4.1 Microsoft Defender for Cloud — Defender Plans (Detection Angle)	38
Mechanism — Defender Plans	38
Alternatives and complements	39
4.2 Microsoft Sentinel	39
Mechanism	40
Where it falls short / alternatives	41
4.3 Azure Monitor & Log Analytics	41
Key capabilities	41
4.4 Azure Activity Log	42

4.5 NSG Flow Logs & VNet Flow Logs	43
4.6 Microsoft Defender for Identity	44
4.7 Detect Function — Summary Table	44
5. RESPOND	46
5.1 Microsoft Sentinel Playbooks & Azure Logic Apps	46
Mechanism	46
5.2 Azure Functions — Automated Remediation	47
5.3 Microsoft Defender for Cloud — Automated Response Actions.....	48
5.4 Azure WAF & Azure Firewall — Active Response	48
5.5 The Multi-Source Detection & Remediation Pipeline Pattern — Azure Variant	49
5.6 Respond Function — Summary Table	50
6. RECOVER.....	51
6.1 Azure Backup.....	51
Mechanism	51
Alternatives	52
6.2 Storage Redundancy, Soft Delete & Immutable Blob Storage	52
6.3 Azure Site Recovery	53
6.4 Azure Resource Manager Templates / Bicep — Recovery Angle	54
6.5 Multi-Subscription Recovery Pattern — Summary.....	55
6.6 Recover Function — Summary Table	55
Appendix A — Full Service Cross-Reference Matrix	57
Appendix B — Architecture Principles Referenced Throughout	58

Purpose & Framework Note

This document is a deep technical reference for Microsoft Azure security services, organized around the NIST Cybersecurity Framework (CSF) 2.0's six functions — Govern, Identify, Protect, Detect, Respond, Recover — using the same structure as the companion AWS Security Services reference. It is written for security architects, cloud security engineers, and detection engineering teams operating a multi-subscription, multi-cloud SaaS environment, and assumes familiarity with core Azure concepts (subscriptions, Entra ID, VNETs) rather than re-explaining them from first principles.

A note on terminology: CSF vs. RMF

As established in the companion AWS document: NIST publishes two related but distinct frameworks. The NIST Risk Management Framework (RMF, SP 800-37) is a structured, document-heavy process for federal information systems built around formal Authorization to Operate. The NIST Cybersecurity Framework (CSF 2.0) is the outcome-based, six-function model — Govern, Identify, Protect, Detect, Respond, Recover — that most commercial and SaaS organizations actually use to structure a security program. This document uses CSF's six functions as the organizing structure for the same reasons given in the AWS reference, and so that both documents can be read side by side using one consistent framework across both clouds.

How to use this document

- Each service entry covers: what it actually does mechanically (not the marketing description), the specific configuration knobs that matter in practice, where it's the right tool versus where it falls short, and the Azure-native or third-party alternatives worth knowing about.
- Every service includes a set of three real-world implementation scenarios — one each for Banking/Financial Services, SaaS/Multi-Tenant Platform, and E-Commerce — grounded in the kind of specific architectural decision, trade-off, or near-miss that actually comes up in practice for that industry.
- Where an Azure service maps closely to a service already covered in the companion AWS document (Key Vault to KMS/Secrets Manager, NSGs to Security Groups, Azure Backup to AWS Backup, and so on), the scenario text explicitly cross-references the AWS pattern, since many organizations operate both clouds and benefit from seeing the same architectural principle expressed on both platforms' equivalent primitives.
- Several services appear in more than one function section, deliberately — Azure Policy, Defender for Cloud, Microsoft Purview, and Entra Permissions Management each have genuinely distinct mechanical roles depending on which function lens you're viewing them through.
- Each major section closes with a summary table for quick reference; the full cross-reference matrix is in the appendix.

Key Structural Differences from the AWS Reference

A few architectural differences between the two clouds are worth flagging up front, since they affect how directly a control maps across the two documents rather than being a pure one-to-one substitution:

- **Azure Policy is dual-purpose:** where AWS splits prevention (SCPs) and detection (Config rules) across two services, Azure Policy does both through its effect types (Deny vs. Audit) in one service, with DeployIfNotExists adding an active-remediation capability that has no single direct AWS equivalent.
- **Entra ID is a full identity provider, not just an authorization layer:** Entra ID natively handles SAML/OIDC federation and directory services in a way AWS IAM, which assumes an external identity provider for federation, does not — Entra ID's scope is structurally closer to combining IAM, IAM Identity Center, and a chunk of Cognito's federation capability into one service.

- **Sentinel and Logic Apps are natively the same automation fabric:** a Sentinel playbook is a Logic Apps workflow, collapsing what AWS splits across EventBridge, Lambda, and Step Functions into one more unified authoring experience.
- **Key Vault combines what AWS splits three ways:** secrets, encryption keys, and certificates live in one service with one access model, where AWS uses Secrets Manager, KMS, and ACM as three separate services.
- **Resource hierarchy depth differs:** Azure's Management Group → Subscription → Resource Group → Resource chain has one more level of native nesting than AWS's Organization → OU → Account → Resource model, and Azure's hierarchy supports deeper OU-equivalent nesting (management groups up to six levels) than is typical in AWS OU design.

1. GOVERN

The Govern function establishes the management group hierarchy, subscription topology, policy-as-code guardrails, and audit posture that every other function depends on. In a multi-subscription Azure estate, Govern is the set of structural decisions — management group design, Azure Policy assignment scope, delegated RBAC at the management group level — that determines whether Protect, Detect, and Respond controls can be enforced consistently across every subscription rather than negotiated subscription by subscription.

1.1 Azure Management Groups, Subscriptions & Resource Hierarchy

Azure's governance hierarchy is Tenant (the Entra ID directory) → Management Groups → Subscriptions → Resource Groups → Resources. Management groups are the direct analog to AWS Organizational Units — they're the level at which Azure Policy and RBAC are assigned so they inherit downward to every subscription and resource underneath, rather than being configured per subscription.

Mechanism

A tenant has a single root management group, beneath which an organization typically creates a small number of top-level management groups (commonly mirroring the Cloud Adoption Framework's reference: Platform, Landing Zones, Sandbox, Decommissioned), with further nesting by environment or business unit underneath. Policy and RBAC assignments at any management group level apply to every subscription nested beneath it — a policy denying public network access on storage accounts, assigned at the Landing Zones management group, applies to every subscription in every business unit underneath without being configured per subscription.

Subscriptions remain the billing and hard-isolation boundary — many Azure resource quotas, and some security boundaries (a subscription-level Azure DDoS Protection plan, for instance), are scoped at the subscription level, so subscription design is itself a security decision, not purely a cost-allocation one. The common pattern for regulated or multi-tenant workloads is one subscription per environment per business unit (e.g., separate production and non-production subscriptions per product line) rather than co-locating environments inside a single subscription distinguished only by resource group.

Resource Hierarchy and RBAC Inheritance

Management Group	Highest assignable scope below the tenant root. Policy and RBAC inherit down to every subscription and resource nested beneath. A tenant can nest management groups up to six levels deep.
Subscription	Billing boundary and the scope for several hard security limits (DDoS Protection plans, some Microsoft Defender for Cloud plan configurations). Also the natural boundary for delegating full administrative control to a business unit without granting tenant-wide access.
Resource Group	Logical container for resources sharing a lifecycle (typically deployed and deleted together). RBAC and some policies can scope to a resource group, but resource groups are not a strong security isolation boundary the way a subscription is — two resources in the same resource group are not isolated from each other by the resource group construct itself.
Azure Lighthouse	Extends cross-tenant delegated access — lets a central security team (or an MSSP) manage resources across multiple customer or subsidiary tenants from one control plane without per-tenant credential switching, the rough analog to AWS's cross-account delegated administrator pattern but operating across tenant boundaries rather than within one organization.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Separate management groups isolating a card-issuing subsidiary from retail banking

A bank with a card-issuing subsidiary operating under its own regulatory scope structures its management group hierarchy with the card-issuing business under its own dedicated top-level management group, entirely separate from retail banking — meaning a policy or RBAC change made for retail banking's landing zones can never accidentally apply to the card-issuing environment, and the bank can produce a clean, scoped compliance report for the card-issuing regulator that doesn't require manually filtering out unrelated retail-banking subscriptions.

SAAS / MULTI-TENANT PLATFORM

Subscription-per-environment design enabling clean blast-radius containment

A SaaS platform restructures from a single shared subscription holding both staging and production resources (distinguished only by resource group naming convention) into separate subscriptions per environment, specifically after a near-miss where a Terraform misconfiguration nearly applied a destructive change across both environments simultaneously because they shared a subscription-level quota and policy scope — the separation means production-scoped Azure Policy assignments and subscription-level DDoS Protection plans can never be accidentally weaker than intended due to a staging-environment exception leaking across.

E-COMMERCE

Azure Lighthouse enabling a central security team to manage newly acquired regional storefront tenants

An e-commerce company that acquires regional competitors in different markets, each running their own pre-existing Azure tenant, uses Azure Lighthouse to extend centralized security monitoring and policy management into each acquired tenant immediately post-acquisition — without needing to first complete the slower, multi-month process of fully migrating each acquired tenant's subscriptions into the parent company's tenant, closing the gap where a newly acquired business would otherwise run with no central oversight for months.

Where it falls short

Unlike AWS SCPs, Azure Policy (covered next) is the enforcement mechanism, not the management group construct itself — a management group with no policies assigned provides organizational structure but no actual guardrails. Management group design is necessary scaffolding, not sufficient protection on its own; it has to be paired with policy assignment at the right scope to do anything.

1.2 Azure Policy & Initiatives

Azure Policy is the direct functional analog to a combination of AWS SCPs and AWS Config rules in one service — it can both prevent (deny effect, blocking a non-compliant resource from being created at all) and detect (audit effect, flagging existing non-compliant resources without blocking anything), which is a meaningfully different model from AWS's split between SCPs (prevention only) and Config (detection only).

Mechanism

Policy effects	Deny (blocks the non-compliant request outright, the SCP-equivalent behavior), Audit (flags non-compliance without blocking, the Config-rule-equivalent behavior), Append/Modify (automatically adds or corrects properties on a resource at creation, e.g., forcing a required tag), DeployIfNotExists (automatically deploys a companion resource if a prerequisite is missing, e.g., auto-enabling diagnostic settings), and Disabled.
Initiatives	A grouped set of individual policy definitions assigned together as a single unit — the direct analog to an AWS Conformance Pack. Microsoft publishes built-in initiatives for CIS Azure Foundations Benchmark, NIST 800-53, PCI-DSS, and others, assignable at any management group or subscription scope.

Policy assignment scope and exemptions	A policy or initiative is assigned at a specific scope (management group, subscription, or resource group) and applies to everything beneath it; specific resources can be granted a documented, time-bound exemption rather than the policy being weakened for everyone — exemptions are themselves logged and reportable, which is the control point auditors check to ensure exceptions are deliberate and tracked rather than silent.
Compliance state & remediation tasks	Azure Policy continuously evaluates assigned resources and reports a compliance percentage per initiative; for Audit-effect policies on already-existing non-compliant resources, a remediation task can retroactively apply a DeployIfNotExists or Modify policy to bring existing resources into compliance, not just prevent new non-compliant ones.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Deny-effect policy blocking creation of any storage account without customer-managed key encryption in the cardholder-data landing zone

A bank assigns a custom Azure Policy with a Deny effect at the cardholder-data-environment management group specifically blocking the creation of any storage account that doesn't have customer-managed key (CMK) encryption configured via Key Vault — meaning a developer cannot accidentally create a PCI-scope storage account with default Microsoft-managed encryption even temporarily, since the deployment itself fails at creation time rather than being flagged after the fact for a security team to chase down.

SAAS / MULTI-TENANT PLATFORM

DeployIfNotExists policy guaranteeing every new subscription gets diagnostic settings wired to the central Log Analytics workspace automatically

A SaaS platform onboarding new product teams onto their own subscriptions uses a DeployIfNotExists policy assigned at the Landing Zones management group that automatically deploys the correct diagnostic settings configuration — routing Activity Log and resource-level diagnostic logs to the central security Log Analytics workspace — onto every new subscription the moment it's created, removing the recurring failure mode where a new team's subscription went live for weeks with no logs reaching central security monitoring simply because nobody manually configured the diagnostic settings.

E-COMMERCE

Custom initiative encoding the company's own PCI-relevant architecture standard, with tracked exemptions for legacy systems

An e-commerce company builds a custom Azure Policy initiative encoding its own internal standard for any subscription touching payment data — requiring Private Link for all storage and database access, denying public IP assignment on any VM in the payment-processing resource groups, and requiring Key Vault-backed encryption — and assigns it at the relevant subscriptions, with one legacy subsystem still mid-migration granted a documented, time-bound policy exemption that automatically expires and re-flags for review after 90 days rather than becoming a silent, permanent carve-out nobody revisits.

Real-world implementation note

The highest-leverage Azure Policy pattern most organizations underuse is DeployIfNotExists for security baseline configuration (diagnostic settings, Defender for Cloud plan enablement, required tags) rather than relying purely on Deny/Audit. Deny stops bad things; DeployIfNotExists actively creates the good configuration without anyone having to remember to do it manually, which is the more reliable control for baseline hygiene that's easy to forget under deadline pressure.

Alternatives / Complements

There's no real alternative to Azure Policy as the native enforcement mechanism within Azure — it is the foundation Azure landing zone reference architectures, Microsoft Defender for Cloud's recommendations, and most third-party CSPM tooling either build on or replicate. For organizations standardizing policy-as-code across Azure, AWS, and GCP from a single tool, Open Policy Agent (OPA) or HashiCorp Sentinel applied at the Terraform-plan stage provide cross-cloud consistency, though they operate pre-deployment rather than as Azure Policy's continuous, post-deployment runtime enforcement.

1.3 Microsoft Purview Compliance Manager

Compliance Manager is Microsoft's compliance posture and assessment tool — distinct from Azure Policy's technical control enforcement, Compliance Manager tracks the broader compliance program: control implementation status against named regulatory frameworks, assigned improvement actions, and an aggregated compliance score, blending both Microsoft's own control implementation (for the shared-responsibility portions Microsoft owns) and the customer's own control implementation status.

Mechanism

- Assessments map a chosen regulatory template (ISO 27001, NIST 800-53, PCI-DSS, GDPR, and many others) to specific control actions, each assigned an owner, a due date, and an implementation status — turning a compliance framework from a static document into a tracked, assignable workflow.
- Microsoft-managed actions within an assessment are pre-populated with Microsoft's own audited control implementation evidence for the Azure platform itself, while customer-managed actions are the portion the organization has to implement and evidence themselves — making the shared-responsibility boundary explicit and trackable per control rather than an abstract concept.
- Compliance score is a weighted aggregate across all assessments, intended as an executive-level trend metric rather than a literal audit pass/fail determination — useful for board-level reporting on compliance posture trajectory over time.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Tracking control ownership across the bank's PCI-DSS assessment ahead of the annual QSA review

A bank's compliance team uses a Compliance Manager PCI-DSS assessment to assign each control action to a named control owner (a specific engineering team lead, a specific compliance analyst) with a due date, replacing what had previously been a shared spreadsheet that frequently fell out of date between the people responsible for technical implementation and the compliance team tracking overall status — going into the annual QSA review, the assessment's implementation status and evidence links are the actual source of truth rather than a separate document reconstructed for the audit.

SAAS / MULTI-TENANT PLATFORM

Using the Microsoft-managed action evidence directly in enterprise customer security questionnaires

A SaaS platform's sales engineering team, responding to an enterprise prospect's ISO 27001 control-mapping questionnaire, pulls the Microsoft-managed action evidence directly from their Compliance Manager ISO 27001 assessment for the controls Microsoft's platform itself satisfies, combining it with their own customer-managed action evidence for the controls the SaaS company implements itself — giving a complete, control-by-control answer rather than a generic statement that they run on a compliant cloud provider.

E-COMMERCE

Trending the compliance score as a board-level KPI ahead of a planned international expansion

Ahead of expanding into a new market with its own data-protection regulation, an e-commerce company's security leadership tracks the relevant Compliance Manager assessment's score trend over the two quarters leading up to launch as a board-reported KPI, giving leadership a concrete, trending signal of readiness rather than a binary, last-minute compliance determination delivered the week before launch.

This service has no direct technical-enforcement alternative — it complements rather than replaces Azure Policy and Defender for Cloud, which provide the actual technical control evaluation. Compliance Manager's customer-managed actions often link back to as evidence.

1.4 Microsoft Entra Permissions Management — Governance Angle

Entra Permissions Management (the evolution of the CloudKnox acquisition) is Microsoft's CIEM (Cloud Infrastructure Entitlement Management) offering — and notably, it is multi-cloud by design, covering AWS and GCP entitlements alongside Azure, not an Azure-only tool. Its governance-relevant capability, distinct from the exposure-finding angle covered under Identify, is continuous least-privilege policy generation and access-review workflow integration.

- Permissions creep index (PCI — unrelated to the payment card standard of the same acronym) is a single risk score per identity reflecting the gap between granted and actually-used permissions, trended over time as a governance KPI.
- Generated least-privilege policies, based on observed usage, are the Azure-and-multi-cloud analog to AWS Access Analyzer's policy generation — a draft, rightsized role definition a human reviews and approves rather than hand-auditing usage logs.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Cross-cloud entitlement governance for a bank running both Azure and a legacy AWS footprint post-acquisition

A bank that acquired a fintech running primarily on AWS, while the bank's own core infrastructure is Azure-based, uses Entra Permissions Management's multi-cloud coverage to get one consistent entitlement-risk view and one generated least-privilege workflow across both clouds during the integration period, rather than running two entirely separate entitlement review processes with two different tools and two different risk-scoring methodologies during an already-complex post-acquisition integration.

SAAS / MULTI-TENANT PLATFORM

Quarterly permissions-creep-index review identifying the engineering team's most over-provisioned service principals

A SaaS platform's quarterly access review uses the Permissions Creep Index to rank every service principal and managed identity by the gap between granted and used permissions, surfacing that a handful of CI/CD service principals carry Owner-level access at the subscription scope despite the generated least-privilege analysis showing they only ever use a narrow set of deployment-related permissions — converting what used to be a manual, low-coverage spot-check review into a ranked, comprehensive list the security team can work through systematically.

E-COMMERCE

Generated least-privilege role replacing a contractor's broad Contributor access after project completion

Following the completion of a third-party contractor engagement that had been granted Contributor access at the resource group level for convenience during the project, an e-commerce company's security team runs Entra Permissions Management's generated least-privilege analysis against the contractor's actual usage history before formally closing out the engagement — confirming the access can simply be fully revoked rather than needing to be preserved in any reduced form, since the generated policy showed no meaningful ongoing usage pattern that would have indicated lingering automation still depending on that access.

1.5 Govern Function — Summary Table

Service	Primary Role	Pairs With
Management Groups & Subscriptions	Resource hierarchy, policy/RBAC inheritance scope	Azure Policy, Azure Lighthouse
Azure Policy & Initiatives	Preventive (Deny) and detective (Audit) guardrails	Defender for Cloud, Resource Graph
Microsoft Purview Compliance Manager	Compliance program tracking & control ownership	GRC platforms, Azure Policy evidence
Entra Permissions Management	Cross-cloud CIEM, least-privilege governance	Entra ID Governance, PIM

2. IDENTIFY

Identify is the function most teams underinvest in relative to its leverage: you cannot protect, detect against, or assess risk on an asset, identity, or dataset you don't know exists. In a multi-tenant SaaS environment running across multiple clouds, asset and data inventory drift is constant, and Azure's own resource sprawl across subscriptions tends to outpace any manually maintained inventory within months of a platform team not actively chasing it down.

2.1 Microsoft Defender for Cloud — CSPM & Posture

Defender for Cloud is Azure's native CNAPP — combining cloud security posture management (CSPM, free at the Foundational tier) with a set of paid Defender plans providing workload-specific threat protection (covered under Detect in Section 4.1). The CSPM half, relevant here, continuously assesses resource configuration against built-in and custom security standards and produces a Secure Score.

Mechanism

- Secure Score aggregates weighted recommendations across every assessed resource into a single percentage, with each recommendation showing exactly which resources are non-compliant and the specific remediation steps — the practical unit a security team tracks as a trending KPI and uses to prioritize remediation effort by points-of-impact rather than just severity.
- Regulatory compliance dashboard maps Defender for Cloud's underlying assessments against named standards (CIS Azure Foundations, PCI-DSS, ISO 27001, NIST 800-53, SOC 2) without needing separate tooling — the Azure-native equivalent of Security Hub's compliance standards in AWS.
- Cloud Security Explorer (the attack-path and exposure graph capability) correlates identity, network exposure, and vulnerability data into a queryable graph — Azure's answer to Wiz's graph-based exposure analysis, narrowing what was historically the biggest capability gap versus dedicated CNAPP vendors.
- Multi-cloud connectors extend Defender for Cloud's CSPM coverage to AWS and GCP accounts, giving a genuinely single-pane posture view across all three major clouds rather than requiring a separate tool — a meaningfully different starting position than AWS Security Hub, which has no native multi-cloud connector model.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Secure Score-driven remediation prioritization ahead of a regulatory technology risk exam

A bank's cloud security team uses Defender for Cloud's Secure Score point-of-impact ranking to prioritize remediation work in the eight weeks ahead of a scheduled regulatory technology risk examination, focusing first on the small number of recommendations carrying the highest score weight (network segmentation gaps on cardholder-data subscriptions, missing disk encryption on a handful of legacy VMs) rather than working through the much longer list of lower-weight findings — moving the Secure Score and, more importantly, closing the specific gaps most likely to be flagged in the exam, within the available time.

SAAS / MULTI-TENANT PLATFORM

Multi-cloud connector giving one posture view across an Azure-primary platform with an AWS-hosted acquired product

A SaaS platform built primarily on Azure acquires a smaller competitor whose product runs on AWS. Rather than running two entirely separate CSPM tools during the (multi-quarter) migration period, the security team connects the acquired company's AWS account to Defender for Cloud via its multi-cloud connector, giving one Secure Score and one regulatory compliance dashboard spanning both clouds immediately — letting the central security team maintain consistent oversight during the integration without waiting for the technical migration to finish first.

E-COMMERCE

Cloud Security Explorer surfacing an actual exploitable attack path the raw recommendation list missed

An e-commerce company's raw Defender for Cloud recommendation list shows two separate medium-severity findings — a publicly exposed VM with a known vulnerability, and an overly permissive managed identity attached to that same VM with write access to the production database — listed as two disconnected medium items. Cloud Security Explorer's attack-path graph instead surfaces these as a single connected exploitable path from internet exposure to database write access, correctly re-prioritizing what the raw recommendation list had under-weighted as two separate, individually less urgent findings.

Where it falls short

- Secure Score weighting can deprioritize findings that matter more in a specific business context than Microsoft's generic weighting assumes — a security team still needs business and data-classification context layered on top, not a pure score-driven worklist.
- The multi-cloud connector model, while a genuine differentiator versus AWS-native tooling, is still generally regarded as less deep on AWS- and GCP-specific nuance than a dedicated multi-cloud CNAPP vendor (Wiz, Prisma Cloud) that built multi-cloud support as its primary product thesis from day one rather than as an extension of a single-cloud-native tool.

Alternatives / Complements

Wiz and Prisma Cloud remain the dominant dedicated CNAPP alternatives, frequently chosen specifically for stronger cross-cloud consistency and a more mature attack-path graphing product when an organization's cloud footprint is genuinely multi-cloud-primary rather than Azure-primary with secondary clouds. For organizations standardizing entirely on the Microsoft security stack, Defender for Cloud's tight native integration with Sentinel and Entra ID is the offsetting advantage a bolt-on third-party CNAPP doesn't replicate as cleanly.

2.2 Microsoft Defender Vulnerability Management

Defender Vulnerability Management (available as a Defender for Servers add-on, and natively for endpoints via Defender for Endpoint) provides agent-based and agentless vulnerability scanning for VMs, plus software inventory, and — distinctly from Defender for Cloud's broader CSPM scope — security baseline assessment against CIS benchmarks at the OS configuration level.

Mechanism

Agentless VM scanning	Snapshot-based scanning of VM disks without requiring an agent inside the guest OS — useful for getting baseline coverage across a fleet quickly, including VMs where agent deployment hasn't happened yet or isn't feasible.
Defender for Endpoint-integrated scanning	For VMs and endpoints with the Defender agent deployed, provides continuously updated, real-time vulnerability data rather than periodic snapshots, plus software inventory showing exactly which versions of which software are installed across the fleet.
Security baselines	Assesses VM OS configuration against CIS benchmark baselines (distinct from vulnerability scanning — this is configuration hardening assessment, e.g., password policy settings, audit logging configuration at the OS level) and reports drift from the chosen baseline.
Container registry scanning	Scans container images in Azure Container Registry for known vulnerabilities, with continuous re-evaluation as new CVEs are published against stored image manifests — directly analogous to Amazon Inspector's ECR re-scan behavior.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES**Agentless scanning providing immediate baseline coverage during a rushed cloud migration**

During an accelerated lift-and-shift migration of a legacy trading-support application under business pressure to vacate an on-prem data center by a fixed deadline, the bank's security team relies on Defender Vulnerability Management's agentless scanning to get immediate vulnerability visibility into the newly migrated VMs before the Defender agent rollout (which required change-management approval through a slower process) had been completed — ensuring there was no gap period where newly migrated, internet-adjacent VMs had zero vulnerability visibility simply because the agent deployment process was still in progress.

SAAS / MULTI-TENANT PLATFORM**Security baseline drift detection catching an OS-level audit-logging setting disabled during a performance-tuning exercise**

A SaaS platform's database-tier VMs had their OS-level audit logging setting disabled by an engineer during a performance-tuning exercise investigating disk I/O contention, without realizing this setting was also a CIS benchmark baseline requirement feeding the company's SOC 2 evidence. The security baseline drift report flags the deviation within the next scheduled assessment cycle, well before it would have surfaced as a finding during the actual SOC 2 audit fieldwork months later.

E-COMMERCE**Container registry re-scanning catching a newly disclosed CVE in the checkout service's base image**

An e-commerce platform's checkout microservice container image, pushed and scanned clean months earlier, gets flagged by Defender Vulnerability Management's continuous container registry re-scanning when a critical CVE is disclosed in a base-image package weeks later — triggering an automated ticket via Logic Apps before any external disclosure or customer report, the same re-scan-on-new-CVE pattern that matters in AWS Inspector applying identically here.

Real-world implementation note

As with AWS Inspector, the highest-leverage configuration is enabling Defender Vulnerability Management across every subscription via Azure Policy's DeployIfNotExists effect at the management group level, and routing findings continuously into the RBVM/ASPM platform (ArmorCode) rather than triaging inside the Defender console — the console is a strong data source and a weak remediation-tracking workflow at any real scale.

Alternatives

Tenable and Qualys remain common where an organization needs one vulnerability management tool spanning on-prem, Azure, AWS, and GCP with a single licensing model and risk-scoring methodology consistent across all of them. Snyc and Wiz both provide stronger developer-workflow-integrated container and IaC scanning than Defender's native tooling offers.

2.3 Microsoft Purview — Data Discovery & Classification

Purview is Microsoft's unified data governance and protection platform, and its data map and classification capabilities are the Azure analog to Macie — but notably broader in scope than Macie's S3-only reach, since Purview's data map can scan Azure SQL, Cosmos DB, Azure Data Lake Storage, and (via its data map connectors) on-prem and even some third-party sources, not just blob storage.

Mechanism

- Automated scanning and classification uses built-in and custom sensitive information types (SSNs, credit card numbers, organization-specific identifiers via custom pattern matching) to classify data across

connected sources, building a searchable data map showing where sensitive data actually lives across the estate.

- Data Map lineage tracking shows how data flows between connected sources — relevant for understanding not just where sensitive data sits at rest, but how it propagates through a pipeline, which matters for accurately scoping which downstream systems also need to be treated as in-scope once a sensitive data source feeds them.
- Sensitivity labels (shared with Microsoft Purview Information Protection) can be applied to classified data and carried through into access policies and DLP rules, including in Microsoft 365 contexts — relevant for SaaS companies whose own internal use of Microsoft 365 alongside their Azure-hosted product creates two parallel surfaces needing consistent data classification.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Data lineage tracing showing exactly which downstream reporting systems inherited PII from a core customer database

A bank's data governance team uses Purview's lineage tracking to trace every downstream system that consumes data originating from the core customer-master database, discovering that a quarterly regulatory reporting pipeline three hops downstream inherits several PII fields through a transformation step that wasn't previously documented as handling personal data — reclassifying that reporting system's data-handling scope and access controls accordingly, a gap that would have been very difficult to find through documentation review alone given how many undocumented hops existed between the source and that specific downstream consumer.

SAAS / MULTI-TENANT PLATFORM

Classifying sensitive data across Cosmos DB multi-tenant collections that Macie-equivalent S3-only tooling couldn't reach

A SaaS platform storing primary application data in Cosmos DB rather than blob storage — a common pattern that would leave a Macie-equivalent, blob-only classification tool with no visibility at all — uses Purview's broader data map connectors to scan and classify sensitive data directly within Cosmos DB collections, discovering that a specific container used for customer support ticket metadata contained more identifiable customer information than the original data model design had assumed, prompting a targeted access-control tightening on that specific container.

E-COMMERCE

Custom sensitive information type catching internal loyalty-program member ID patterns in an analytics export

An e-commerce company configures a custom sensitive information type in Purview matching its specific loyalty-program member ID format (distinct from any built-in PII pattern), then runs classification scans against a marketing analytics data lake export — discovering that loyalty member IDs were present in an export the marketing analytics team had assumed was already de-identified, since the de-identification process had only stripped names and emails without anyone realizing the member ID itself was also a reidentifiable personal identifier under the company's own privacy policy definition.

Limitations and alternatives

Purview's scanning and classification breadth is a genuine strength relative to Macie's S3-only scope, but the platform's full capability set (especially Information Protection labeling integration with Microsoft 365) is most valuable to organizations already invested in the broader Microsoft 365/Purview ecosystem; a purely Azure-infrastructure-focused team may find a narrower, infrastructure-specific DSPM tool (Wiz's DSPM module, BigID) simpler to operate for pure cloud-data-store classification without the broader governance platform overhead.

2.4 Azure Resource Graph

Resource Graph is Azure's fast, cross-subscription, cross-tenant (with appropriate access) resource query service — the direct analog to AWS Resource Explorer, but with a materially more expressive query language (KQL, Kusto Query Language) rather than a simpler search-by-tag-or-type interface.

- Because Resource Graph uses KQL, the same query language used across Azure Monitor, Log Analytics, and Sentinel, a security team can write one complex query joining resource configuration data with security-relevant properties (e.g., find every public IP address attached to a VM in a specific resource group that also lacks an NSG association) in a way that's considerably more powerful than tag-or-type filtering alone.
- Resource Graph queries can run across every subscription a credential has access to in a single call, which is what makes it the practical tool for an incident responder needing to find every instance of a specific resource pattern across a large multi-subscription estate quickly.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Cross-subscription KQL query finding every VM with a public IP and no NSG during an emergency exposure sweep

Following disclosure of a critical, actively-exploited vulnerability affecting a specific VM image type, a bank's incident response team runs a single Resource Graph KQL query across all 40+ subscriptions to find every VM built from that image with a public IP address and either no NSG or an NSG permitting broad inbound access — getting a definitive, complete answer within minutes rather than needing every subscription owner to individually check and report back, which under emergency time pressure would have been both slower and less reliable.

SAAS / MULTI-TENANT PLATFORM

Scheduled Resource Graph query feeding a tag-compliance dashboard across 100+ engineering-owned subscriptions

A SaaS platform's cloud governance team schedules a recurring Resource Graph query (run via Logic Apps on a daily schedule) checking every resource across all engineering-owned subscriptions for the required cost-center and data-classification tags, feeding a dashboard the platform team uses to chase down tagging gaps — providing the same kind of continuously updated compliance signal Azure Policy's tag-enforcement could provide preventively, but applied retroactively across the substantial number of older resources created before the tagging policy was put in place.

E-COMMERCE

Finding every orphaned public storage endpoint left behind by decommissioned regional microsites

An e-commerce company's security team runs a Resource Graph query specifically looking for storage accounts with public network access enabled that have had zero access logged in the preceding 90 days, surfacing several storage accounts left behind by decommissioned regional promotional microsites whose application infrastructure had been torn down but whose storage account — holding old campaign images — had been missed by the teardown automation, an easy gap to create when resource deletion isn't fully centralized in one pipeline.

Alternatives

Azure Policy's compliance state view provides a more structured, continuously-evaluated inventory for anything already covered by an assigned policy; Resource Graph is the better tool for ad hoc, exploratory, or incident-time queries that don't map to a pre-existing policy definition. Third-party CSPM tools (Wiz, Prisma Cloud, Defender for Cloud's own Cloud Security Explorer) again provide a maintained, continuously updated resource graph with security context layered on top, which is generally a better day-to-day posture interface than raw Resource Graph queries for anything beyond targeted, ad hoc investigation.

2.5 Entra Permissions Management — Exposure Findings

The exposure-finding half of Entra Permissions Management (the governance/policy-generation half is covered in Section 1.4) surfaces over-privileged identities, unused permissions, and risky permission combinations — including cross-cloud, covering AWS and GCP identities alongside Entra ID and Azure RBAC.

- **Risk dashboard:** highlights super-identities (identities with permissions far exceeding their observed usage), inactive identities still holding active permissions, and specific high-risk permission combinations (e.g., an identity that can both modify IAM/RBAC policy and access sensitive data, a toxic combination an attacker would specifically seek out).

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Identifying a toxic permission combination on a CI/CD service principal before it became an incident

A bank's Entra Permissions Management risk dashboard flags a CI/CD pipeline's service principal as holding both Key Vault secret-read access and the ability to modify RBAC role assignments — a toxic combination that would let a compromise of that single service principal both steal credentials and grant itself broader access to cover its tracks — and the finding prompts splitting that single overprivileged service principal into two narrowly-scoped ones before the combination was ever exploited.

SAAS / MULTI-TENANT PLATFORM

Surfacing dormant former-employee guest accounts still holding active Azure RBAC roles

A SaaS platform's quarterly access review, run through Entra Permissions Management, surfaces several guest accounts (B2B-invited external collaborators from a since-ended consulting engagement) that still hold active Contributor-level Azure RBAC roles on several subscriptions despite zero login activity in over six months — a gap that had persisted because guest account offboarding wasn't part of the same automated employee-offboarding workflow that handled internal employee departures.

E-COMMERCE

Cross-cloud super-identity detection on a service account with both Azure and AWS access following a hybrid integration project

Following a hybrid-cloud integration project connecting an e-commerce company's primary Azure environment to an AWS-hosted analytics platform, Entra Permissions Management's cross-cloud view flags the integration's service identity as a super-identity on both sides — holding broad Azure Contributor access and a similarly broad AWS IAM policy, despite the actual integration only needing read access to a narrow set of resources on each side — prompting a joint Azure-and-AWS least-privilege rightsizing exercise using the tool's generated policy recommendations on both clouds simultaneously.

2.6 Identify Function — Summary Table

Service	Primary Role	Pairs With
Defender for Cloud (CSPM)	Posture management, Secure Score, attack-path graph	Sentinel, multi-cloud connectors, Wiz/Prisma
Defender Vulnerability Management	VM/container vulnerability & baseline scanning	Defender for Endpoint, ArmorCode, Tenable
Microsoft Purview	Cross-source sensitive data discovery & classification	Information Protection, DSPM tools
Azure Resource Graph	Fast cross-subscription KQL-based resource queries	Azure Policy, Sentinel, IR workflows

Service	Primary Role	Pairs With
Entra Permissions Management	Cross-cloud entitlement exposure & risk scoring	Entra ID Governance, PIM

3. PROTECT

Protect is the largest function by service count because it spans identity, data, and network — the three control domains where a multi-tenant SaaS platform carries the most risk of cross-tenant compromise. As with the AWS treatment of this function, the organizing principle worth restating: every Protect control here should be evaluated not just on whether it stops an external attacker but on whether it stops tenant A from ever touching tenant B's data or compute.

3.1 Microsoft Entra ID (Azure AD)

Entra ID is Azure's identity platform — the control plane for both workforce and, via Entra External ID, customer identity, and the foundation every other Protect control in this section ultimately depends on for authentication and authorization decisions. It is materially different in scope from AWS IAM: Entra ID is a full identity provider (supporting SAML, OIDC, and WS-Fed federation natively) and directory service, not purely an authorization policy engine layered on a separate identity store the way IAM is.

Core Mechanism

- Azure RBAC (the authorization layer governing access to Azure resources) is distinct from Entra ID roles (which govern access to Entra ID/directory-level administrative functions like user and app management) — a frequent point of confusion, since both use the word role but operate at entirely different scopes and are managed through different blades in the portal.
- Service principals and managed identities are the workload-identity equivalents of AWS IAM roles — a managed identity (system-assigned, tied to a specific resource's lifecycle, or user-assigned, a standalone identity that can be attached to multiple resources) lets an Azure resource authenticate to other Azure services without any credential ever being stored or managed by the application, the direct analog to IAM instance profiles or IRSA.
- App registrations represent an application's identity for OAuth 2.0/OIDC purposes, generating the service principal that's actually granted permissions — understanding the app registration vs. service principal distinction matters because permissions are granted to the service principal, while the app registration defines the application's identity and OAuth configuration (redirect URIs, exposed APIs, requested scopes).

ABAC and Multi-Tenant Isolation in Azure RBAC

Azure RBAC conditions (the ABAC-equivalent capability) allow attribute-based restrictions on role assignments — for example, restricting a Storage Blob Data Reader role assignment so it only applies to blobs with a specific blob index tag matching the requesting identity's own tag claim, which is the Azure mechanic behind the same kind of tenant-scoped, claims-driven access pattern described for AWS ABAC session tags. Azure RBAC conditions currently support a narrower set of resource types than AWS's ABAC model covers across its broader service surface, which is a real constraint worth validating against the specific resource types a given architecture needs to scope.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

User-assigned managed identity shared across a fleet of regulatory-reporting Function Apps without credential sprawl

A bank's regulatory reporting pipeline runs across a dozen Azure Function Apps, each needing the same scoped access to a specific Key Vault and storage account. Rather than provisioning a dozen separate system-assigned managed identities (one per function, tied to each function's own lifecycle) or worse, a shared static credential, the bank uses a single user-assigned managed identity attached to all twelve Function Apps — meaning the access grant is defined once, audited once, and if one Function App is decommissioned, the identity and its grants persist cleanly for the remaining eleven rather than needing to be recreated.

SAAS / MULTI-TENANT PLATFORM**Azure RBAC conditions scoping blob access by tenant tag, mirroring the AWS ABAC session-tag pattern**

A multi-tenant SaaS platform storing tenant file uploads in Azure Blob Storage applies a blob index tag containing the owning tenant ID to every uploaded blob, then uses an Azure RBAC condition on the application's managed identity role assignment restricting Storage Blob Data Reader access to only blobs whose tenant-id tag matches a claim asserted at request time — providing the same kind of cryptographically-enforced, claims-driven tenant boundary IAM ABAC session tags provide in AWS, as a second independent control layered behind the application's own authorization logic.

E-COMMERCE**Distinguishing app registration redirect-URI misconfiguration from service-principal over-permissioning during a security review**

During a security review of the e-commerce platform's customer-facing OAuth integration allowing third-party loyalty-partner apps to access limited customer data with consent, the review separately validates the app registration's configured redirect URIs (catching one partner integration with an overly broad wildcard redirect URI that could have enabled an authorization-code-interception attack) and the corresponding service principal's granted API permissions (confirming they were correctly scoped to only the consented data) — explicitly treating these as two distinct review items rather than one, since a correctly-scoped service principal behind a loosely-configured app registration is still a real vulnerability.

Real-world implementation note

The single highest-leverage Entra ID hardening step most organizations still haven't done, directly mirroring the AWS guidance: driving the count of standing, non-expiring high-privilege role assignments toward zero, replacing them with Privileged Identity Management's just-in-time activation (Section 3.3). A near-zero count of permanently-active Global Administrator or Owner role assignments is a far more meaningful governance metric than most posture scores.

Where it falls short / common failure modes

- Guest (B2B) account lifecycle management is a frequent governance gap — external collaborators invited for a specific project often retain active access long after the project (and sometimes the relationship) has ended, since guest account offboarding isn't always wired into the same automated process as employee offboarding.
- Legacy authentication protocols (POP3, IMAP, older Exchange protocols that don't support modern authentication/MFA) remain a meaningful attack surface in tenants that haven't explicitly blocked them, since credential-stuffing tools specifically target these protocols as an MFA bypass path.

Alternatives / Complements

There is no real alternative to Entra ID as the tenant's own identity provider once an organization is on Microsoft 365/Azure — the meaningful architecture decisions are around Conditional Access policy design and PIM adoption rather than choosing a different core IdP. Okta and Ping Identity remain relevant in hybrid scenarios where an organization runs Okta as the primary enterprise IdP and federates into Entra ID for Azure/M365 access specifically, rather than making Entra ID the IdP of record.

3.2 Entra Conditional Access

Conditional Access is Entra ID's policy engine for context-aware, risk-based access control — evaluating signals (user/group, device compliance state, location, sign-in risk level, application being accessed) at every sign-in and applying a defined control (block, require MFA, require a compliant device, require a specific authentication strength) in response. It is the central nervous system of Zero Trust enforcement in a Microsoft-centric identity architecture.

Mechanism

Signals	User/group membership, named locations (including IP-based trusted-network definitions), device platform and compliance state (via Intune), client app type, real-time and aggregate sign-in risk (from Entra ID Protection), and the specific cloud app being accessed.
Controls	Block access, grant access requiring one or more conditions (MFA, compliant device, hybrid Azure AD joined device, approved client app, terms-of-use acceptance, or a specific authentication strength like phishing-resistant MFA).
Session controls	Beyond the binary grant/block decision, session controls can enforce app-enforced restrictions (limited functionality on unmanaged devices), Conditional Access App Control (real-time session monitoring and control via Microsoft Defender for Cloud Apps), and sign-in frequency requirements forcing periodic re-authentication.
Report-only mode	Lets a new policy run in evaluation mode against real sign-in traffic, logging what it would have done without actually enforcing it — the standard, necessary step before rolling out any new Conditional Access policy broadly, since an overly aggressive policy enforced without this testing step can lock out an entire user population with no warning.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Phishing-resistant authentication strength required for any access to the core-banking administrative app

A bank's Conditional Access policy for its core-banking administrative console requires a specific authentication strength — phishing-resistant MFA (FIDO2 security keys or certificate-based authentication) — rather than just any MFA method, specifically closing the gap that SMS- or push-notification-based MFA leaves open to real-time phishing relay (adversary-in-the-middle) attacks, a control the bank's threat intelligence team specifically prioritized after seeing this attack pattern used against peer institutions.

SAAS / MULTI-TENANT PLATFORM

Device-compliance requirement scoped only to engineers with production data-plane access, not the whole company

A SaaS platform's Conditional Access policy requiring a compliant, Intune-managed device applies specifically to the group of engineers with standing access to production data-plane resources, rather than the entire company — a deliberate scoping decision balancing security posture against the operational friction of mandating managed devices company-wide, reasoning that the marginal risk reduction from extending the requirement to, say, the marketing team accessing only SaaS productivity tools didn't justify the added device-management overhead for that population.

E-COMMERCE

Report-only mode catching that a new location-based policy would have blocked the on-call rotation's legitimate remote access

Before enforcing a new Conditional Access policy restricting administrative access to a defined set of named office locations, an e-commerce company's security team runs the policy in report-only mode for two weeks first — discovering it would have blocked several legitimate after-hours incident-response logins from on-call engineers working from home, which hadn't been accounted for in the initial named-location list, and adjusting the policy to instead require a compliant managed device rather than a fixed location before enforcing it for real.

Where it falls short

Conditional Access policies can interact in non-obvious ways when multiple policies apply to the same sign-in event, and a policy that looks correct in isolation can produce unexpected results combined with others — report-only mode and Entra ID's What If tool (which simulates how existing policies would evaluate for a specific user/app/condition combination) should be standard practice before any policy change, not just for brand-new policies.

3.3 Entra ID Governance — PIM, Access Reviews & Entitlement Management

Entra ID Governance is a suite of capabilities — Privileged Identity Management (PIM), Access Reviews, and Entitlement Management — that together form Azure's native approach to the lifecycle problem AWS addresses through a combination of Identity Center permission sets, Access Analyzer, and manual access reviews. It is more built-out as a single, integrated governance product than the AWS equivalent, reflecting Entra ID's broader identity-platform scope.

Privileged Identity Management (PIM)

PIM converts standing privileged role assignments (both Entra ID roles and Azure RBAC roles) into eligible assignments — a user is eligible for a role but not actively granted it, and must explicitly activate it for a time-bound window (often requiring justification, approval, and MFA at activation time) to actually exercise the privilege. This is the direct mechanism for eliminating always-on administrative access, conceptually similar to requiring an AWS break-glass process for root access, but built as a first-class, self-service workflow for any privileged role rather than a manual break-glass procedure reserved for the most extreme cases.

Access Reviews and Entitlement Management

- Access Reviews automate recurring recertification campaigns — a designated reviewer (often the resource owner or the user's manager) is periodically prompted to confirm a user's continued need for a given role assignment or group membership, with automatic removal on a no-response or explicit deny outcome, turning quarterly access review from a manual spreadsheet exercise into a tracked, semi-automated workflow.
- Entitlement Management packages a defined bundle of access (specific group memberships, app role assignments, SharePoint site access) into an Access Package that users can request through a self-service catalog, with defined approval workflows and automatic expiration — the practical mechanism for giving a new contractor or cross-team collaborator exactly the access their role needs without a security engineer manually assembling individual grants, and with that access automatically expiring rather than persisting indefinitely.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Just-in-time PIM activation replacing standing Global Administrator assignments ahead of a regulatory exam

Following a prior exam finding that several IT staff held standing Global Administrator access with no time limit, a bank converts every Global Administrator and other Tier-0 Entra ID role to PIM-eligible-only, requiring justification, manager approval, and MFA for any activation, with a maximum activation window of four hours — the next exam cycle confirms zero standing high-privilege assignments exist outside a documented, time-bound activation event, directly closing the prior finding with an auditable activation log as evidence rather than a policy document describing intended practice.

SAAS / MULTI-TENANT PLATFORM

Entitlement Management self-service access package for new engineers joining a specific product squad

A SaaS platform with frequent new-hire onboarding across dozens of product squads replaces the previous manual process (a new engineer's manager emailing a list of needed access to the platform team, who

assembled it by hand) with an Entitlement Management access package per squad, bundling the correct Entra ID groups, Azure RBAC role assignments on the squad's subscriptions, and relevant SharePoint access into one requestable package with manager approval and automatic 12-month expiration — cutting new-engineer access provisioning from days to hours while also ensuring access doesn't silently persist indefinitely after a later role change.

E-COMMERCE

Quarterly access review automatically revoking unused vendor-integration access nobody had remembered to clean up

An e-commerce company's quarterly Access Review campaign, targeting all guest accounts and externally-facing app role assignments, surfaces a third-party logistics vendor's integration account that still held an active app role assignment six months after that integration had actually been decommissioned in favor of a newer vendor — the access review's automatic-removal-on-no-response policy revokes the unused assignment without requiring a security engineer to have separately tracked and remembered to clean it up after the integration changeover.

Real-world implementation note

PIM's value compounds specifically when paired with Conditional Access — requiring phishing-resistant MFA and a compliant device as a condition of role activation, not just at initial sign-in, closes the gap where a session hijacked after initial authentication could otherwise be used to activate a privileged role without re-proving identity.

Alternatives

Saviynt and SailPoint are the common dedicated identity governance and administration (IGA) platforms organizations adopt when they need governance spanning far beyond Entra ID and Azure — covering on-prem Active Directory, SaaS applications, and custom in-house applications under one unified access-review and entitlement-management program, which Entra ID Governance natively scopes primarily to Microsoft-ecosystem resources.

3.4 Azure Key Vault & Managed HSM

Key Vault is Azure's secrets, keys, and certificate management service — functionally combining what AWS splits across Secrets Manager, Parameter Store, and KMS into a single service with three distinct object types (secrets, keys, certificates) under one access-control and auditing model.

Mechanism

Secrets	Arbitrary string values (API keys, connection strings, passwords) — the Secrets Manager/Parameter Store equivalent, with native versioning and configurable expiration.
Keys	Cryptographic keys used for encrypt/decrypt, sign/verify, and wrap/unwrap operations — the KMS equivalent, supporting both software-protected keys (in the standard, multi-tenant Key Vault tier) and HSM-protected keys (in the Premium tier or Managed HSM).
Certificates	Manages the full certificate lifecycle including automated renewal, integrating with both Microsoft and supported third-party CAs — a capability AWS splits out into the separate ACM service, but Azure includes natively in Key Vault.
Access model: Access Policies vs. Azure RBAC	Key Vault supports two distinct authorization models — the legacy vault-level Access Policy model (coarse, vault-wide permissions) and the newer Azure RBAC model (fine-grained, supports Azure RBAC conditions, consistent with how every

	other Azure resource is authorized) — Microsoft's explicit guidance is to use the RBAC model for any new vault, since the Access Policy model cannot express the same granularity and doesn't benefit from PIM-based just-in-time elevation.
Managed HSM	A dedicated, single-tenant FIPS 140-2 Level 3 HSM pool, distinct from the logically-isolated multi-tenant HSM backing Premium-tier Key Vault keys — the direct analog to AWS CloudHSM, used when compliance specifically mandates dedicated hardware custody rather than a shared (even if logically isolated) HSM fleet.
Soft-delete and purge protection	Soft-delete retains a deleted vault or object in a recoverable state for a defined retention period; purge protection additionally prevents permanent deletion even by a privileged administrator until that retention period expires — the Key Vault equivalent of S3 Object Lock, and increasingly required by Azure Policy in regulated environments specifically because without it, a compromised or malicious administrator could permanently destroy key material instantly.

CMK/CMEK Pattern for Multi-Tenant Isolation

Directly mirroring the AWS KMS per-tenant CMEK pattern: a multi-tenant Azure platform can use a dedicated Key Vault key per tenant (or per tenant tier) for customer-managed key encryption of tenant data in Storage or Cosmos DB, with Azure RBAC role assignments (potentially combined with RBAC conditions) scoping which managed identity can use which tenant's key — providing the same cryptographic, independent-of-application-logic tenant boundary described in the AWS document's KMS section, implemented on Azure's equivalent primitives.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Purge protection and Managed HSM together satisfying a regulator's key-custody and destruction-resistance requirements

A bank's core-banking encryption keys are stored in Managed HSM (satisfying a payment-network certification requiring dedicated, single-tenant HSM custody, the same requirement that drove the CloudHSM scenario in the AWS document) with purge protection enabled and a 90-day soft-delete retention window — meaning that even a compromised or rogue administrator with apparent full privileges cannot immediately and irrecoverably destroy the bank's encryption keys, a specific destruction-resistance guarantee the bank's operational resilience assessment required as evidence before approving the cloud migration.

SAAS / MULTI-TENANT PLATFORM

Per-tenant Key Vault keys for CMEK encryption of Cosmos DB data, scoped via Azure RBAC conditions

Directly mirroring the AWS KMS per-tenant CMEK pattern: a B2B SaaS platform storing tenant data in Cosmos DB uses a dedicated Key Vault key per enterprise-tier tenant for customer-managed key encryption, with the application's managed identity granted Key Vault Crypto User access scoped via an Azure RBAC condition matching the tenant context asserted in the request — so a compromised path to one tenant's decrypt capability cannot be used against another tenant's data even if the application's own authorization logic were bypassed, the same independent cryptographic backstop the AWS document describes for the KMS-and-Secrets-Manager pairing.

E-COMMERCE

Automated certificate renewal eliminating a recurring class of checkout-page outage

An e-commerce platform previously suffered an outage when a manually-tracked TLS certificate for a regional storefront domain expired without the renewal reminder being acted on in time. Migrating certificate issuance and renewal to Key Vault, integrated with the platform's Application Gateway and Front Door instances, made renewal fully automatic and removed the dependency on a human noticing and acting on an

expiration reminder — directly eliminating the failure category, the same outcome ACM provides on the AWS side.

Real-world implementation note

Migrate any vault still on the Access Policy model to Azure RBAC authorization as a standing priority — beyond the granularity improvement, the RBAC model is what allows PIM just-in-time elevation for Key Vault access, meaning a security engineer can require time-bound, justified, approved access even to read a secret rather than holding standing access permanently.

Alternatives

HashiCorp Vault remains a common alternative specifically for organizations wanting one secrets-management tool spanning Azure, AWS, GCP, and on-prem with a consistent API and policy model, at the cost of operating and securing Vault's own infrastructure rather than consuming a fully managed service.

3.5 Azure Web Application Firewall (WAF)

Azure WAF is not a standalone service but a capability attached to one of three front-end services — Azure Front Door, Application Gateway, or Azure CDN — and the choice of which front-end hosts the WAF has real architectural consequences, unlike AWS WAF's more uniform attachment model across CloudFront, ALB, and API Gateway.

Mechanism

- WAF policies contain managed rule sets (the Default Rule Set/DRS, based on OWASP Core Rule Set, plus a Bot Manager rule set) and custom rules, each with an action (Allow, Block, Log, Redirect, or in the newer policy model, also supporting rate limiting and geo-filtering as first-class custom rule match conditions).
- Front Door WAF operates at the global edge, evaluating traffic before it reaches any regional back end — the right choice for a globally distributed application where you want attack traffic blocked as close to its origin as possible, never reaching any specific region's infrastructure at all.
- Application Gateway WAF operates regionally, integrated with the regional Application Gateway — the right choice when the application is single-region or region-specific WAF policy tuning is needed (different rule exceptions per region, for instance).
- Bot Manager rule sets provide managed bot-detection signatures, distinguishing known-good bots (search engine crawlers) from malicious/unknown bots, conceptually similar to AWS WAF's Bot Control managed rule group.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Front Door WAF blocking credential-stuffing traffic at the global edge before it reaches any regional banking back end

A bank operating regional online-banking deployments across multiple geographies puts Front Door WAF in front of all of them, with a custom rate-based rule and the Bot Manager rule set specifically tuned against credential-stuffing patterns on the shared login path — meaning a credential-stuffing wave originating from any geography is blocked at the nearest edge location globally, never reaching any specific region's back-end infrastructure or consuming that region's compute capacity, regardless of which regional deployment the attacker was actually targeting.

SAAS / MULTI-TENANT PLATFORM

Application Gateway WAF with per-region custom rule exceptions for a region-specific legacy API quirk

A SaaS platform with a single-region-per-customer deployment model (some enterprise customers require data residency in a specific Azure region) uses regional Application Gateway WAF instances rather than Front Door specifically because one region's deployment still runs a legacy API integration with response patterns that occasionally trip a generic DRS rule incorrectly — the regional WAF model lets that one region carry a narrowly scoped rule exception without affecting the WAF policy applied to every other region's gateway.

E-COMMERCE

Bot Manager distinguishing legitimate price-comparison crawlers from scraping bots during a product-catalog scraping incident

An e-commerce platform experiencing aggressive scraping of its product catalog and pricing data initially considered blocking all non-human traffic outright, until Bot Manager's distinction between known-good bots (legitimate price-comparison services and search engine crawlers the business wanted to keep allowing) and unverified/malicious bots let the team block the actual scraping traffic specifically without also cutting off the price-comparison referral traffic that was a meaningful and intentional customer-acquisition channel.

Where it's best used

The Front Door vs. Application Gateway WAF decision should be driven by the application's own topology — global, multi-region applications generally benefit from Front Door's edge-level blocking; single-region or data-residency-constrained applications often have no real choice but Application Gateway. Running both in sequence (Front Door at the edge, Application Gateway regionally) is a legitimate defense-in-depth pattern for the highest-value applications.

Alternatives

Cloudflare WAF remains the common third-party alternative/complement, chosen for the same reasons it's favored alongside AWS WAF — broader bot-mitigation maturity and a CDN/WAF/DDoS bundle that operates consistently regardless of which cloud sits behind it, relevant for organizations running both Azure and AWS who want one WAF vendor and policy model across both.

3.6 Azure DDoS Protection

Azure DDoS Protection has two tiers: Basic, automatically enabled at no cost for every Azure resource with no configuration, providing always-on traffic monitoring and automatic mitigation of common network-layer attacks; and the paid Network Protection tier, providing tuned, resource-specific mitigation policies, attack analytics and reporting, and SLA-backed guarantees plus cost protection for resource scaling during an attack — directly analogous to the Shield Standard/Advanced split in AWS.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

DDoS Rapid Response support engagement during a sustained attack timed to a public news event

Following extensive negative press coverage, a bank's public-facing digital banking platform experiences a sustained volumetric attack. The Network Protection tier's DDoS Rapid Response support team is engaged directly, providing real-time mitigation tuning specific to the observed attack pattern beyond the bank's own pre-configured policies — and the tier's cost protection guarantee subsequently covers the App Service and Application Gateway scaling costs incurred during the multi-day attack window.

SAAS / MULTI-TENANT PLATFORM

Tuned, resource-specific mitigation policies reducing false-positive mitigation during a legitimate traffic spike

A SaaS platform on the Basic tier alone experienced a brief period during a legitimate viral traffic spike where automatic DDoS mitigation, tuned only to generic thresholds, briefly throttled some legitimate traffic alongside the spike. Upgrading to Network Protection allowed configuring resource-specific mitigation

policies with thresholds calibrated to the platform's own known traffic patterns, meaning a future similar legitimate spike is distinguished correctly from an actual attack rather than triggering the same generic threshold.

E-COMMERCE

Attack analytics reporting used as evidence in a cyber-insurance claim following a competitor-suspected DDoS campaign

After a sustained DDoS campaign during a major promotional event, suspected (though never conclusively attributed) to be competitor-motivated, an e-commerce company uses Network Protection's detailed attack analytics and mitigation reports as supporting documentation for a cyber-insurance claim covering the lost-revenue impact of the brief availability degradation that occurred before mitigation fully engaged — the kind of detailed, exportable attack telemetry the Basic tier's always-on but less detailed protection wouldn't have provided.

- Alternatives: Cloudflare's DDoS protection remains the dominant alternative/complement, for the same multi-cloud-consistency and network-scale reasons described in the AWS Shield section.

3.7 Azure Firewall & Firewall Manager

Azure Firewall is a managed, stateful, cloud-native network firewall — the direct analog to AWS Network Firewall, though built on Microsoft's own engine rather than Suricata, with Firewall Manager serving the same centralized, cross-subscription policy orchestration role that AWS Firewall Manager fills, but specifically for Azure Firewall, WAF policies, and DDoS Protection plans together.

Mechanism

Network and application rules	Network rules filter on IP/port/protocol; application rules filter on FQDN (including wildcard FQDN tags for common Microsoft service categories), giving domain-based filtering similar to AWS Network Firewall's domain lists without needing a separate proxy.
Threat intelligence-based filtering	Can automatically alert on or deny traffic to/from IP addresses and domains identified as malicious by Microsoft's own threat intelligence feed, operating as a baseline layer beneath custom rules.
Premium tier: TLS inspection & IDPS	The Premium SKU adds TLS inspection (decrypt, inspect, re-encrypt) and a full intrusion detection and prevention system with signature-based filtering — the direct analog to Network Firewall's Suricata-based IDS/IPS capability.
Firewall Manager	Centrally manages Azure Firewall policies, WAF policies, and DDoS Protection plan associations across multiple Azure Firewall instances and subscriptions from one place, with hierarchical policies (a parent policy's rules can be inherited and extended by child policies per region or business unit) — directly analogous to AWS Firewall Manager's cross-account policy enforcement, but covering this specific set of network/edge controls.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Hierarchical Firewall Manager policy enforcing a bank-wide domain allow-list with a regional exception layer

A bank uses a hierarchical Firewall Manager policy with a parent policy defining the bank-wide mandatory domain allow-list (core vendor APIs, regulatory reporting endpoints) applied to every Azure Firewall instance across every region and subsidiary, while permitting each regional child policy to add a small number of region-specific approved domains (a local regulatory reporting endpoint specific to that jurisdiction) —

guaranteeing the bank-wide baseline can never be weakened by a regional exception, while still allowing legitimate regional variation.

SAAS / MULTI-TENANT PLATFORM

Premium-tier IDPS catching lateral movement signatures inside the platform's internal VNet peering mesh

A SaaS platform centralizes all inter-VNet traffic through a hub VNet running Premium-tier Azure Firewall with IDPS enabled in alert-and-deny mode, which flags and blocks a signature match consistent with SMB-based lateral movement originating from a compromised build-tooling VM attempting to reach an unrelated production VNet it had no legitimate dependency on — the centralized hub architecture meaning this detection and block happens once, centrally, rather than requiring per-VNet network security tooling.

E-COMMERCE

FQDN application rules restricting outbound traffic from the payment-processing subnet to only the payment gateway's documented endpoints

An e-commerce platform's payment-processing subnet routes all outbound traffic through Azure Firewall with application rules permitting only the specific, documented FQDNs of its payment gateway provider and tokenization service — denying all other outbound destinations by default, directly limiting the blast radius of any compromised dependency in that subnet attempting to exfiltrate data to an unapproved destination, the same centralized-egress-allow-listing rationale described for AWS Network Firewall.

- Alternatives: third-party NGFW appliances from the Azure Marketplace (Palo Alto, Fortinet, Check Point) offer more advanced application-layer inspection and a centralized multi-cloud management console for organizations standardizing on one of these vendors across Azure, AWS, and on-prem.

3.8 Network Security Groups, Application Security Groups & VNet Architecture

NSGs are the closest Azure analog to AWS security groups, but with a meaningfully different evaluation model worth being precise about, since the AWS-to-Azure mental model mapping here is one of the most common sources of misconfiguration for teams operating both clouds.

Network Security Groups (NSGs)	Unlike AWS security groups (allow-only, stateful), NSGs support both Allow and Deny rules, evaluated in priority order (lowest number evaluated first, first match wins), and can attach to either a subnet or an individual network interface — a closer mental model to AWS NACLs in supporting explicit deny, but stateful like AWS security groups for return traffic. Mixing subnet-level and NIC-level NSGs on the same resource, with rules evaluated in a defined combined order, is a frequent source of confusion when migrating mental models directly from AWS's single-construct security group approach.
Application Security Groups (ASGs)	A logical grouping construct referenced within NSG rules, the Azure equivalent of AWS's security-group-referencing pattern — an NSG rule can permit traffic from/to an ASG rather than a CIDR, so as VMs are added to or removed from an ASG, the relevant NSG rules apply automatically without per-rule maintenance.
Private Link & Private Endpoints	A Private Endpoint brings a private, VNet-internal IP address for a PaaS service (Storage, SQL Database, Key Vault) directly into a VNet, the direct analog to AWS PrivateLink/VPC Interface Endpoints — traffic to the service never traverses the public internet even though the service itself is platform-managed, not VM-hosted.
Service Endpoints	An older, simpler mechanism than Private Endpoints — extends the VNet's identity (not a private IP, just network-level routing optimization and the ability to restrict the PaaS resource's firewall to a specific VNet/subnet) onto the Microsoft backbone for the supported PaaS service's public endpoint, still using the service's

	public IP but routed over the backbone rather than the public internet. Private Endpoints are the more modern, more secure pattern Microsoft now recommends in most cases, but Service Endpoints remain relevant for cost-sensitive or simpler scenarios not needing a fully private IP.
Private Link Service (for exposing your own service)	The reverse direction from Private Endpoints — lets you expose your own service to other VNets (including customer-owned VNets, including across tenants) via a Private Link Service, the direct analog to AWS PrivateLink's VPC endpoint service capability for SaaS providers offering customers a private connectivity option.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Private Link Service offering a corporate-treasury customer a no-public-internet connectivity option, mirroring the AWS PrivateLink pattern

Directly mirroring the AWS PrivateLink banking scenario: a bank's corporate-treasury product exposes a Private Link Service so large enterprise customers whose own security policy prohibits public-internet paths to treasury systems can create a Private Endpoint in their own VNet connecting to the bank's service entirely over the Azure backbone — with the bank's NSGs on the receiving subnet further restricted to deny any traffic not originating from an approved Private Endpoint connection, layering NSG-level enforcement on top of the network-path guarantee Private Link itself provides.

SAAS / MULTI-TENANT PLATFORM

Application Security Groups simplifying NSG rule management across an autoscaling microservice fleet

A SaaS platform's internal microservice architecture assigns every VM in the order-processing tier to an order-processing ASG and every VM in the inventory tier to an inventory ASG, with a single NSG rule permitting traffic from the order-processing ASG to the inventory ASG on the required port — as both tiers autoscale throughout the day, new VMs automatically inherit correct connectivity the moment they're added to the relevant ASG, eliminating the same kind of manual CIDR-rule-maintenance burden the AWS security-group-referencing pattern addresses.

E-COMMERCE

Private Endpoint enforcement ensuring product-catalog Cosmos DB access never traverses the public internet, even internally

An e-commerce platform's product-catalog Cosmos DB account has its public network access fully disabled, reachable only via a Private Endpoint from the application VNet — combined with the Cosmos DB account's own firewall configuration restricting connections to that Private Endpoint specifically, this guarantees catalog data retrieval has no network path through the public internet even if application credentials were somehow used from outside the VNet, directly mirroring the S3-Gateway-Endpoint-plus-bucket-policy pattern described for AWS.

Architecture pattern worth calling out explicitly

A mature Azure hub-and-spoke VNet design uses a central hub VNet (peered to every spoke VNet) hosting Azure Firewall for centralized egress filtering and Azure Bastion for centralized administrative access, with Private Endpoints for PaaS services placed either centrally in the hub or per-spoke depending on whether the service is shared infrastructure or workload-specific — the direct Azure analog to the AWS Transit-Gateway-plus-inspection-VPC reference pattern.

3.9 Azure Front Door & Azure CDN

Front Door (Microsoft's modern, actively developed offering) and the legacy Azure CDN product both provide global content delivery and edge presence, but Front Door has become the standard choice for new deployments

specifically because it integrates WAF, more sophisticated routing, and security capabilities Azure CDN's older tiers don't carry natively.

Private Link origin support	Front Door Premium can reach an origin (an App Service, an internal load balancer, a Storage account) via Private Link, meaning the origin can have zero public internet exposure at all and still be served globally through Front Door — directly analogous to combining CloudFront's OAC with a private S3 origin, but extended to a broader range of origin types than CloudFront's S3/ALB-centric model.
Rules Engine	Allows custom request/response manipulation logic at the edge — header injection (security headers, similar to CloudFront's response headers policy), URL rewrites, and conditional routing based on request attributes, all evaluated before the request reaches origin.
Managed TLS and end-to-end TLS	Front Door can both terminate TLS at the edge with a managed certificate and re-encrypt the connection to origin, ensuring the entire path is encrypted even though Front Door itself inspects the traffic for WAF evaluation in between.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Private Link origin keeping the online-banking App Service fully unreachable from the public internet directly

A bank's online-banking App Service has all public network access disabled, reachable only through Front Door Premium's Private Link origin connection — meaning the only valid network path to the banking application is through Front Door's edge (with WAF, rate limiting, and the bank's custom security rules already applied), and there is no direct-to-origin path an attacker could discover and exploit to bypass the edge controls entirely, a specific architecture decision the bank's penetration testers validate during every annual assessment by confirming no direct origin IP is reachable.

SAAS / MULTI-TENANT PLATFORM

Rules Engine injecting per-tenant security headers and routing based on custom-domain matching

A SaaS platform supporting tenant custom domains uses Front Door's Rules Engine to inject a Content-Security-Policy header whose value varies based on which tenant's custom domain the request matched, and to route requests to the correct backend pool based on the Host header — centralizing logic that would otherwise need to be duplicated across every origin application instance, and ensuring every tenant's custom domain gets consistent baseline security headers regardless of which engineering team owns the specific service handling that tenant's traffic.

E-COMMERCE

End-to-end TLS with WAF inspection protecting checkout traffic without creating a plaintext gap anywhere in the path

An e-commerce platform's checkout flow runs through Front Door with end-to-end TLS configured — TLS terminated at the edge for WAF inspection, then a separate TLS connection re-established to the origin — ensuring there is no unencrypted hop anywhere in the request path despite the edge needing to inspect the traffic in plaintext momentarily to apply WAF rules, satisfying a PCI requirement around encryption of cardholder data in transit across every network segment the traffic crosses.

Alternatives

Cloudflare and Fastly remain the dominant third-party alternatives, for the same reasons described in the AWS CloudFront section — broader edge network maturity in some regions and more sophisticated bot/edge-compute capabilities, frequently run as the primary edge layer with Front Door or CloudFront relegated to a secondary or origin-specific role in mixed-cloud architectures.

3.10 Azure DNS & Private DNS

Azure DNS handles public DNS zone hosting; Azure Private DNS provides DNS resolution scoped to one or more VNets without exposing internal hostnames publicly. Security-relevant capabilities mirror Route 53's but with some structural differences worth noting.

DNSSEC	Azure DNS's DNSSEC support has historically lagged behind AWS Route 53 and required more manual configuration or third-party tooling in some scenarios — worth explicitly verifying current support status for a given zone configuration rather than assuming parity with Route 53's more mature native implementation.
Private DNS zones and auto-registration	Private DNS zones linked to a VNet, with auto-registration automatically creating DNS records for VMs as they're created — useful for internal service discovery without manual DNS record management, and a private analog to how Route 53 Private Hosted Zones work for AWS.
Azure Firewall DNS proxy / DNS-based filtering	Rather than a dedicated DNS Firewall product, Azure's DNS-layer malicious-domain filtering is typically achieved through Azure Firewall's FQDN filtering and threat-intelligence-based rules (Section 3.7) operating on DNS-derived FQDN data, or through Microsoft Defender for DNS's anomaly detection (covered under Detect, Section 4.1) rather than a separately named DNS Firewall service.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Private DNS zone preventing internal core-banking service hostnames from ever being publicly resolvable

A bank's core-banking microservices use a Private DNS zone linked only to the relevant production VNets, meaning internal service hostnames (which could otherwise hint at internal architecture to an external attacker performing reconnaissance) are never resolvable from outside the VNet at all — a deliberate decision to keep internal naming conventions and service topology entirely invisible externally, distinct from and in addition to the network-level access controls already restricting actual traffic.

SAAS / MULTI-TENANT PLATFORM

Auto-registration simplifying service discovery across a frequently-scaling microservice fleet

A SaaS platform's autoscaling application tier relies on Private DNS zone auto-registration so that as new VM instances scale in and out throughout the day, each automatically receives a DNS record without any manual or scripted DNS management step — removing an entire category of potential misconfiguration where a manually-maintained internal DNS record set could drift out of sync with actual running infrastructure.

E-COMMERCE

FQDN-based Azure Firewall filtering as the practical equivalent of DNS-layer threat blocking for outbound checkout-service traffic

Lacking a directly named DNS Firewall product the way AWS offers, an e-commerce platform achieves the equivalent outbound protection by combining Azure Firewall's threat-intelligence-based FQDN denial with its application rule allow-list scoped to the checkout service's subnet (Section 3.7) — achieving materially the same outbound malicious-domain blocking outcome, implemented through Azure's firewall-centric rather than DNS-resolver-centric architecture for this capability.

Alternatives

Cloudflare DNS remains the common alternative for organizations wanting a single DNS/CDN/WAF vendor; for hybrid environments with substantial on-prem DNS infrastructure, Infoblox remains common for unified DNS/DHCP/IPAM, with Azure DNS handling only the cloud-hosted public zones.

3.11 Azure Application Gateway

Application Gateway is Azure's regional Layer 7 load balancer — distinct from Front Door's global edge scope, Application Gateway operates within a single region/VNet and is the typical attachment point for regional WAF policies (Section 3.5) as well as providing standard L7 load balancing, SSL offload, and URL-based routing.

- Application Gateway's integration with a VNet (it's deployed directly into a subnet, unlike Front Door's fully external, global edge presence) makes it the natural choice when backend pools include resources that should never be directly internet-exposed and the architecture needs the load balancer itself to live inside the same network trust boundary as those backends.
- Autoscaling and zone redundancy are built into the v2 SKU, removing the older manual capacity-planning burden the v1 SKU required.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Application Gateway as the VNet-integrated entry point for a regionally-isolated banking subsidiary's deployment

A bank's regionally-isolated subsidiary, required by local regulation to keep all infrastructure (including the load balancing layer) within a specific region's VNet boundary rather than relying on a global edge service, uses regional Application Gateway as its sole internet-facing entry point — satisfying the data-residency and infrastructure-locality requirement that a global service like Front Door, by its distributed-edge nature, couldn't straightforwardly satisfy in the same way.

SAAS / MULTI-TENANT PLATFORM

URL-based routing directing different tenant-tier traffic to differently-sized backend pools

A SaaS platform uses Application Gateway's URL-based routing to direct enterprise-tier tenant traffic (identified via a path prefix set by an upstream routing layer) to a dedicated, more generously provisioned backend pool, while standard-tier tenant traffic routes to a shared pool — letting one Application Gateway instance serve differentiated service tiers without needing entirely separate front-end infrastructure per tier.

E-COMMERCE

Zone-redundant v2 SKU maintaining checkout availability through an availability-zone outage during peak shopping hours

During a regional Azure availability-zone networking incident, an e-commerce platform's zone-redundant Application Gateway v2 deployment continued routing checkout traffic without interruption by automatically shifting load away from the affected zone — validated specifically because the team had deliberately chosen the zone-redundant v2 SKU configuration during initial deployment rather than the simpler single-zone option, a decision made explicitly because of the platform's low tolerance for checkout downtime during peak hours.

3.12 Azure Bastion

Azure Bastion provides browser-based, agentless RDP/SSH access to VMs over TLS through the Azure portal, without exposing any RDP/SSH port on the VM itself to the public internet and without requiring a client-side agent or a traditional self-managed bastion host — the Azure analog to Systems Manager Session Manager, though architecturally a managed PaaS gateway deployed into the VNet rather than an agent-based connection broker.

- Because Bastion is deployed into a dedicated subnet within the target VNet, it provides access without any public IP on the target VMs at all, and every session can be configured to log to a Log Analytics workspace for full audit trail, mirroring Session Manager's complete logged-session capability.

- The Standard/Premium SKU adds session recording (full video/text recording of Bastion sessions, depending on configuration) — a stronger audit capability than Session Manager's command-and-output logging, relevant for environments needing literal session playback as evidence.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Session recording providing literal playback evidence for a privileged-access audit finding

Responding to an auditor's request for evidence of exactly what actions were performed during a specific privileged maintenance window on a core-banking VM, the bank's security team retrieves the full Bastion session recording for that window — providing literal video/text playback of the session rather than reconstructing actions from command logs alone, a stronger evidentiary standard the auditor specifically asked whether the bank's solution could support.

SAAS / MULTI-TENANT PLATFORM

Eliminating public RDP/SSH exposure across hundreds of engineering-managed VMs in one policy change

A SaaS platform's security team, following a routine Defender for Cloud recommendation flagging dozens of VMs across engineering-owned subscriptions with NSG rules permitting public inbound RDP/SSH, mandates Azure Bastion deployment per VNet via an Azure Policy DeployIfNotExists assignment and simultaneously removes all public RDP/SSH NSG rules org-wide — closing what had been a long-standing, widely distributed finding in a single coordinated change rather than chasing down each VM's NSG individually.

E-COMMERCE

Bastion access logged to the same Log Analytics workspace used for the broader detection pipeline

An e-commerce company routes Azure Bastion session logs into the same central Log Analytics workspace feeding its Sentinel detection rules, so an anomalous pattern — a Bastion session from an unusual administrative account connecting to a production database VM outside of any scheduled maintenance window — surfaces through the same detection pipeline used for every other security signal, rather than Bastion access living in an isolated log silo only checked during a dedicated audit.

- Alternatives: Teleport and StrongDM remain common third-party alternatives for the same unified, audited, multi-platform access-broker reasons described in the AWS document, particularly relevant for organizations with meaningful infrastructure outside Azure that they want under one consistent access model.

3.13 Microsoft Defender for Containers / AKS Security

Defender for Containers is the Defender for Cloud plan specifically covering Kubernetes (primarily AKS, but also Arc-enabled Kubernetes clusters on other infrastructure) and container registries — combining configuration posture assessment, runtime threat detection, and vulnerability scanning into one plan, conceptually similar to combining GuardDuty's EKS Protection with Inspector's ECR scanning under one AWS umbrella, but packaged as a single Defender plan rather than split across two separate AWS services.

Mechanism

Cluster configuration assessment	Evaluates AKS cluster configuration against security best practices (similar in spirit to CIS Kubernetes Benchmark) — RBAC configuration, network policy presence, pod security standards — surfaced as Defender for Cloud recommendations feeding the broader Secure Score.
Runtime threat detection	An eBPF-based sensor (deployed as a DaemonSet) provides in-cluster behavioral detection — anomalous process execution, container escape attempts, cryptomining patterns — directly analogous to GuardDuty's EKS Runtime Monitoring agent.

Registry vulnerability scanning	Scans images in Azure Container Registry (and, via Defender CSPM's broader multi-cloud registry support, images in other registries) continuously, re-evaluating stored images as new CVEs are published, mirroring the ECR/Inspector re-scan behavior.
Kubernetes data plane hardening via Azure Policy	AKS-specific Azure Policy definitions (via the Azure Policy Add-on for Kubernetes, built on Gatekeeper/OPA) can enforce admission-control-level policies — blocking privileged container creation, requiring specific labels, restricting allowed container registries — at the Kubernetes API server level, the Azure-native equivalent of Kubernetes admission control policy enforcement.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Runtime detection catching an attempted container escape in an AKS-hosted fraud-scoring workload, mirroring the AWS GuardDuty EKS scenario

Directly mirroring the GuardDuty EKS Runtime Monitoring scenario described for AWS: a bank's real-time fraud-scoring service runs on AKS, and Defender for Containers' runtime sensor flags an anomalous process execution inside a pod — a shell spawned attempting to access the underlying node's instance metadata endpoint — within seconds, triggering automated pod isolation before any escape could succeed in reaching node-level credentials with broader scope than the pod's own identity.

SAAS / MULTI-TENANT PLATFORM

Azure Policy Gatekeeper-based admission control blocking privileged container deployment in shared multi-tenant clusters

A SaaS platform running multi-tenant workloads on shared AKS clusters uses the Azure Policy Add-on for Kubernetes to enforce a cluster-wide admission control policy denying any pod specification requesting privileged container mode or host network access — a hard, API-server-level guardrail preventing a single misconfigured or compromised deployment from ever requesting the kind of elevated container privileges that would meaningfully increase cross-tenant breakout risk in a shared cluster, enforced before the pod is ever scheduled rather than detected afterward.

E-COMMERCE

Continuous registry re-scanning catching a newly disclosed CVE in the checkout service's AKS-deployed container image

Mirroring the Inspector/ECR scenario described for AWS: an e-commerce platform's checkout microservice container image, scanned clean at build time and not rebuilt since, gets flagged by Defender for Containers' continuous Azure Container Registry re-scanning when a critical CVE is disclosed in a base-image package weeks later — triggering an automated Logic Apps workflow before any external disclosure, with zero code change having occurred on the team's side.

Alternatives

Aqua Security, Sysdig, and Wiz's container security modules remain common alternatives for organizations needing consistent container security posture and runtime detection across AKS, EKS, and GKE simultaneously under one tool and one policy language, rather than relying on each cloud's own native Defender/GuardDuty-equivalent separately.

3.14 Azure Storage Account Security

Because Azure Storage (Blob, in particular) is as central to most Azure architectures as S3 is to AWS architectures, and carries the same historical pattern of high-profile exposure incidents, its security controls deserve the same dedicated, non-generic treatment given to S3 in the AWS document.

Disabling public network access entirely	The storage account-level setting blocking all public network access regardless of any individual container's access level setting — the Azure equivalent of S3 Block Public Access, and the recommended default posture enforced via Azure Policy Deny effect, with Private Endpoint access as the explicit, reviewed alternative rather than public access being a default-available option.
Shared Access Signatures (SAS) — and the case for User Delegation SAS specifically	SAS tokens grant time-limited, scoped access to storage resources without sharing the account key — but account-key-based SAS tokens cannot be individually revoked before expiration if compromised, only invalidated by rotating the underlying account key (which invalidates every other SAS token issued from that key too). User Delegation SAS, signed with Entra ID credentials rather than the account key, can be revoked individually and is the strongly recommended pattern for any SAS issued to or on behalf of an external party, for exactly this revocability reason.
Customer-managed keys (CMK) for encryption at rest	Storage account encryption using a Key Vault-housed customer-managed key rather than Microsoft-managed keys — the direct analog to S3's SSE-KMS, giving independent, auditable, revocable control over the encryption key separate from the storage account's own access controls.
Immutable blob storage (time-based retention and legal hold)	WORM enforcement at the blob level — time-based retention policies (cannot be deleted/modified until the retention period expires, even by an account owner) and legal hold (indefinite, manually-released immutability) — the direct analog to S3 Object Lock's governance/compliance modes, covered further in Recover.
Storage Analytics logging & diagnostic settings	Detailed request-level logging for audit and access-pattern analysis, routed to a Log Analytics workspace or storage account — the equivalent role S3 server access logs and CloudTrail data events play for AWS.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Time-based immutability on regulatory record-retention blob storage, mirroring the AWS Object Lock compliance-mode pattern

Directly mirroring the S3 Object Lock compliance-mode scenario described for AWS: a bank subject to a multi-year regulatory record-retention requirement applies a time-based retention policy to the dedicated regulatory-archive storage account, set to the regulatory minimum — meaning no identity, including a compromised or rogue administrator with apparent full account access, can delete or alter those records before the retention period expires, the specific destruction-resistance guarantee the regulation requires.

SAAS / MULTI-TENANT PLATFORM

User Delegation SAS enabling revocable, time-limited access for a customer data-export feature

A SaaS platform's customer data-export feature, granting a customer's own integration temporary access to download their exported data from blob storage, deliberately uses User Delegation SAS rather than account-key-based SAS specifically because of the individual-revocability property — if a specific export's SAS token were later suspected of having leaked, the platform can revoke that one token without needing to rotate the storage account key and invalidate every other active SAS token issued to every other customer in the process.

E-COMMERCE

Disabling public network access account-wide via Azure Policy, closing a gap from a legacy storage account predating the security baseline

An e-commerce company's Azure Policy-driven account-wide enforcement of disabled public network access on all storage accounts catches and auto-remediates a legacy storage account, created years earlier before

the current security baseline existed, that had been left with public blob access enabled on a container holding old promotional campaign assets — a gap that had gone unnoticed specifically because the account predated the team's current default security configuration and had never been swept by a retroactive policy enforcement until this org-wide Deny/remediation policy was rolled out.

3.16 Protect Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
Microsoft Entra ID	Identity & access control plane, workforce + customer identity	Conditional Access, PIM, CIEM tools
Entra Conditional Access	Context-aware, risk-based access policy enforcement	Entra ID Protection, Intune
Entra ID Governance (PIM, Access Reviews)	Just-in-time privilege, recertification, entitlement mgmt	Saviynt, SailPoint
Azure Key Vault / Managed HSM	Secrets, keys, certificates; CMEK	HashiCorp Vault, Managed HSM
Azure WAF (Front Door/App Gateway)	L7 application protection	Cloudflare WAF
Azure DDoS Protection	DDoS protection (Basic/Network Protection)	Cloudflare DDoS
Azure Firewall / Firewall Manager	VNet-level stateful inspection, IDPS, policy orchestration	Palo Alto/Fortinet, hub-spoke VNet
NSGs / ASGs / Private Link	Subnet/NIC network controls, private PaaS connectivity	VNet peering, Private Link Service
Azure Front Door / CDN	Global edge delivery, Private Link origins	Cloudflare, Fastly
Azure DNS / Private DNS	Public & private DNS resolution	Cloudflare DNS, Infoblox
Azure Application Gateway	Regional L7 load balancing, regional WAF attachment	Front Door (global alternative)
Azure Bastion	Agentless, portal-based VM access with session recording	Teleport, StrongDM
Defender for Containers / AKS	Kubernetes posture, runtime detection, registry scanning	Aqua, Sysdig, Wiz container modules
Storage Account security controls	Data-at-rest protection, public access prevention	Purview, immutable blob storage

4. DETECT

Detect is where raw telemetry becomes an actionable signal. As with the AWS treatment of this function, the discipline that separates a mature detection program from a noisy one is not which Azure services are enabled — it's whether findings are correlated, enriched with business context, and routed to the right response path automatically. Microsoft's detection stack is structurally more unified than AWS's: Defender for Cloud's various Defender plans, Sentinel, and Azure Monitor are designed from the outset to interoperate as one connected system rather than several independently-evolved services.

4.1 Microsoft Defender for Cloud — Defender Plans (Detection Angle)

Beyond the free CSPM capability covered under Identify, Defender for Cloud's paid Defender plans provide workload-specific threat detection — the direct analog to GuardDuty's protection plans, but organized as separately enableable, separately priced plans per workload type rather than bundled under one umbrella service.

Mechanism — Defender Plans

Defender for Servers	Endpoint detection and response (via integrated Defender for Endpoint), just-in-time VM access (reducing standing RDP/SSH exposure even before Bastion fully replaces direct access patterns), and adaptive application controls (allow-listing expected running processes per VM, flagging deviations).
Defender for Storage	Detects anomalous access patterns and malware uploaded to storage accounts — including a malware-scanning capability for uploaded blobs — directly analogous to GuardDuty S3 Protection plus a Macie-adjacent malware-scanning capability AWS splits into a separate GuardDuty Malware Protection feature.
Defender for Key Vault	Detects anomalous access patterns and suspicious operations against Key Vault — unusual access volume, access from an unfamiliar location or anomalous application, attempts to access a large number of secrets in a short window — a workload-specific detection category AWS doesn't have a direct single-service equivalent for, since KMS/Secrets Manager anomaly detection on the AWS side is more distributed across GuardDuty's general behavioral analysis rather than a dedicated Key-Vault-specific plan.
Defender for DNS	Detects anomalous DNS query patterns — communication with known-malicious domains, DNS-based data exfiltration patterns, suspicious domain query volume — functionally covering the detection use case Route 53 Resolver query logging plus a SIEM detection rule would cover on the AWS side, but as a named, purpose-built Defender plan.
Defender for Identity	Monitors on-prem Active Directory and Entra ID signals for identity-based attack patterns (covered in more depth in Section 4.5, given its distinct, identity-specific detection model).
Defender for APIs	Detects anomalous API usage patterns and known API attack patterns (the OWASP API Security Top 10 categories) against APIs registered with Azure API Management — a workload-specific detection category without a precise single-service AWS equivalent, since this kind of API-specific behavioral detection is more often assembled from WAF plus custom CloudWatch/GuardDuty logic on the AWS side rather than a dedicated, purpose-built plan.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Defender for Key Vault catching an anomalous bulk-secret-access pattern from a compromised CI/CD identity

A bank's Defender for Key Vault plan flags an anomalous pattern: a CI/CD service principal that historically retrieves only two or three specific secrets per pipeline run suddenly attempts to enumerate and retrieve dozens of secrets across multiple vaults in rapid succession — a pattern consistent with an attacker who has compromised the pipeline's credentials attempting to harvest as many secrets as possible, caught and the credential automatically disabled via the response pipeline within minutes of the anomalous access pattern beginning, well before any of the harvested secrets could be exfiltrated and used elsewhere.

SAAS / MULTI-TENANT PLATFORM**Defender for APIs flagging a credential-stuffing-adjacent enumeration pattern against the platform's public API**

A SaaS platform's public-facing partner API, registered with Azure API Management, has Defender for APIs enabled, which flags a pattern consistent with systematic object-ID enumeration — a single API consumer's credentials being used to request a sequential, rapidly incrementing range of customer record IDs, a classic broken-object-level-authorization (BOLA) exploitation attempt — well before any individual request would have looked anomalous against rate-limiting thresholds alone, since the requests themselves were individually within normal rate limits but anomalous in their sequential access pattern.

E-COMMERCE**Defender for Storage malware scanning catching a malicious file uploaded through a customer-review-image upload feature**

An e-commerce platform's customer product-review feature, allowing users to upload images alongside reviews, has Defender for Storage's malware scanning enabled on the relevant storage account — flagging and automatically quarantining a file uploaded through that feature that matched known malware signatures, despite the file having a benign-looking image file extension, closing a path where the public-facing upload feature could otherwise have been used to stage malware within the company's own trusted storage infrastructure.

Real-world implementation note

Enable the relevant Defender plans org-wide via Azure Policy DeployIfNotExists at the management group level from day one of subscription vending — exactly mirroring the GuardDuty org-wide enablement guidance for AWS. Not every plan is relevant to every subscription (Defender for APIs only matters where API Management is actually in use), so plan enablement should be tied to actual workload presence via policy conditions rather than blanket-enabled regardless of relevance, both for cost reasons and alert-relevance reasons.

Alternatives and complements

CrowdStrike Falcon and SentinelOne provide EDR-grade host-level detection with richer process-tree context than Defender for Servers' integrated capability alone in some comparative evaluations, and are commonly run alongside Defender for Cloud rather than instead of it, mirroring the same EDR-plus-cloud-native-detection pairing described for AWS.

4.2 Microsoft Sentinel

Sentinel is Microsoft's cloud-native SIEM and SOAR platform, built on top of Azure Monitor's Log Analytics workspace — meaningfully more integrated into the broader Azure detection ecosystem than a bolt-on third-party SIEM would be, since Sentinel consumes Defender for Cloud findings, Entra ID sign-in logs, and Azure resource logs natively without separate log-shipping configuration in most cases. This is the rough analog to running Security Hub plus a SIEM plus SOAR playbooks all in one connected product, rather than three separately integrated AWS services.

Mechanism

Data connectors	Pre-built connectors ingest data from Defender for Cloud, Entra ID, Office 365, AWS (via a native connector, relevant for multi-cloud SIEM consolidation), and hundreds of third-party sources — reducing the log-pipeline-engineering burden a from-scratch SIEM deployment usually requires.
Analytics rules	Scheduled, near-real-time, and Fusion (ML-based correlation across multiple weak signals into one higher-confidence incident, similar in spirit to GuardDuty Extended Threat Detection) rule types generate incidents from raw log data — Microsoft publishes a large library of built-in analytics rule templates mapped to MITRE ATT&CK techniques, reducing the detection-engineering effort needed to get meaningful coverage from a cold start.
Entity behavior analytics (UEBA)	Baselines normal behavior per user/entity and flags anomalous deviations — Sentinel's analog to GuardDuty's ML-based behavioral anomaly detection, but applied across the broader set of log sources Sentinel ingests rather than scoped only to AWS-native telemetry.
Playbooks (Logic Apps-based)	Sentinel's automated response capability is built directly on Azure Logic Apps (covered in depth under Respond, Section 5.2) — meaning every Sentinel playbook is also a fully-featured Logic Apps workflow, with the same connector ecosystem available for response actions as for any other Logic Apps automation.
Workbooks	Customizable dashboards built on the underlying Log Analytics KQL queries — the practical interface analysts and leadership use for both investigation and executive-level security metrics reporting.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Fusion correlation combining a low-severity sign-in anomaly with a subsequent data-access pattern into one high-confidence incident

A bank's Sentinel Fusion rule correlates two findings that would otherwise have been triaged separately and likely deprioritized individually — an Entra ID sign-in risk flag (login from a new device, moderate confidence) and, twenty minutes later, an unusual pattern of read access against a customer-data Cosmos DB container from a session originating from that same sign-in — combining them into a single, high-confidence incident indicating a likely account compromise being actively used for data access, mirroring the same value-add described for GuardDuty Extended Threat Detection in the AWS document.

SAAS / MULTI-TENANT PLATFORM

Native AWS connector giving one Sentinel workspace visibility across an Azure-primary platform's secondary AWS footprint

A SaaS platform built primarily on Azure, with a secondary AWS footprint from an acquired product (the same scenario referenced under Defender for Cloud's multi-cloud connector in Section 2.1), uses Sentinel's native AWS connector to ingest CloudTrail and GuardDuty findings directly into the same Sentinel workspace already analyzing Azure-native signals — giving the security team one detection and investigation surface across both clouds during the integration period rather than monitoring two entirely separate SIEM environments.

E-COMMERCE

UEBA flagging an insider-risk pattern of after-hours access to the discount-code generation system

Sentinel's entity behavior analytics flags an employee's access pattern to the platform's discount-code generation system as anomalous against their own established baseline — a marked increase in after-hours access frequency over several weeks, inconsistent with their normal working pattern — prompting a closer review that ultimately substantiates a suspected case of unauthorized discount-code generation for personal

use, a pattern that no single access event would have flagged but that the behavioral baseline comparison surfaced clearly over time.

Where it falls short / alternatives

- Sentinel's cost model (consumption-based, tied to data ingestion volume into Log Analytics) requires active cost management at scale — high-volume log sources (verbose application logs, full network flow data) need deliberate filtering or tiering decisions, or costs can scale unpredictably, a real operational discipline distinct from the underlying detection capability itself.
- Splunk remains the dominant alternative for organizations with an existing significant Splunk investment, deep custom detection content already built, or a genuine need for a SIEM that isn't tied to the Azure/Microsoft ecosystem's own connector and pricing model. Chronicle (Google SecOps) is a third option increasingly considered specifically for its different, often more predictable pricing model for very high-volume log ingestion.

4.3 Azure Monitor & Log Analytics

Azure Monitor (with Log Analytics as its underlying log query and storage engine) is the metrics, logging, and alerting backbone every other Azure detective control is built on — the rough combined analog to CloudWatch and CloudTrail's role in the AWS document, though Azure's architecture routes nearly everything through one unified Log Analytics workspace and KQL query language rather than splitting metrics (CloudWatch) and audit events (CloudTrail) across two more distinctly separate services.

Key capabilities

- Diagnostic settings, configured per-resource (or org-wide via the Azure Policy DeployIfNotExists pattern described in Section 1.2), route resource-level logs and metrics to a Log Analytics workspace, Storage account, or Event Hub — the equivalent decision point to enabling CloudTrail data events or VPC Flow Logs, since most Azure resources don't send detailed logs anywhere by default until diagnostic settings are explicitly configured.
- Log Analytics workspace KQL queries provide the same ad hoc investigation capability CloudWatch Logs Insights provides — frequently the first tool reached for during initial incident triage, and the same query language used by Resource Graph, Sentinel analytics rules, and Defender for Cloud, meaning skill investment in KQL pays off across every layer of the Azure security stack simultaneously.
- Azure Monitor Alerts (metric alerts and log query alerts) provide the same custom, fast-path alerting CloudWatch metric filters and alarms provide — useful for the small set of event categories warranting the fastest possible alert path independent of the broader Sentinel/Defender for Cloud aggregation pipeline.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Fast-path log query alert on Entra ID Global Administrator role activation, bypassing the standard aggregation delay

Directly mirroring the AWS CloudWatch root-account-usage alarm scenario: a bank configures an Azure Monitor log query alert directly against the Entra ID audit log for any Global Administrator PIM activation event, paging the on-call security engineer within roughly a minute via an Action Group — deliberately bypassing the normal Sentinel incident-aggregation pipeline for this one extremely high-severity event category, on the reasoning that Global Administrator activation should always be expected and pre-announced, and any unplanned activation warrants the fastest possible alert path.

SAAS / MULTI-TENANT PLATFORM

KQL ad hoc query during initial triage of a customer-reported cross-tenant data concern

Mirroring the CloudWatch Logs Insights triage scenario described for AWS: a customer reports seeing unfamiliar data in their account dashboard. Before escalating to a full incident process, the on-call engineer runs a Log Analytics KQL query directly against the application's request logs, filtering for any request bearing that customer's tenant ID alongside a response payload size anomaly, getting an initial read within minutes on whether this looks like an isolated rendering bug or an actual cross-tenant data-access issue — informing whether to declare a security incident before the slower, more thorough Sentinel-based investigation even begins.

E-COMMERCE

Diagnostic settings deliberately scoped to checkout and payment resources to control Log Analytics ingestion cost while maintaining forensic readiness where it matters most

An e-commerce platform, mindful of Sentinel/Log Analytics' consumption-based cost model, deliberately enables verbose diagnostic settings (including data-plane-level logging) only on the checkout and payment-processing resource groups specifically, while less sensitive resource groups send only standard activity-level logs — a deliberate cost-versus-forensic-readiness trade-off mirroring the same selective CloudTrail-data-events cost-awareness pattern described for AWS, applied to the resources carrying the highest actual investigative value.

4.4 Azure Activity Log

The Activity Log is the control-plane audit trail of every subscription-level operation — resource creation, deletion, role assignment changes, policy changes — the direct analog to CloudTrail management events, automatically retained for 90 days by default with no configuration required, though a Log Analytics-routed and retained copy (via diagnostic settings, the same mechanism covered in Section 4.3) is necessary for any real investigation or compliance retention requirement beyond that default window.

- Unlike CloudTrail, which requires explicit configuration of a multi-region organization trail to get full coverage, every Azure subscription has Activity Log enabled by default with no setup required — the configuration decision is purely about retention and routing, not whether the audit trail exists at all.
- Activity Log entries include the full operation detail (who, what, when, from where, and the full request/response payload for many operation types) — directly comparable in depth to a CloudTrail management event.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Activity Log providing the definitive record of every RBAC change during a post-incident privilege-escalation investigation

Following a suspected privilege-escalation incident, a bank's investigation relies on the Activity Log's complete record of every role assignment change across the affected subscription in the relevant time window — providing definitive evidence of exactly which role was granted to which principal, by whom, and when, forming the backbone of the incident timeline submitted as part of the bank's regulatory incident disclosure.

SAAS / MULTI-TENANT PLATFORM

Long-term Activity Log retention via Storage account archival supporting a multi-year SOC 2 evidence requirement

A SaaS platform routes Activity Log entries to both Log Analytics (for active querying and Sentinel correlation, retained 90 days in hot storage) and a separate, immutable-blob-storage-backed long-term archive (retained for several years) via diagnostic settings — satisfying their SOC 2 auditor's multi-year audit-trail retention expectation without paying Log Analytics' active-query pricing for data that's rarely queried after the first few months but still needs to be retrievable on demand.

E-COMMERCE

Confirming no unauthorized resource deletions occurred during a suspected insider-access incident

During an internal investigation into a departing employee's access in their final two weeks before offboarding, an e-commerce company's security team queries the Activity Log specifically for any delete operations performed by that employee's account across every subscription they had access to — confirming no unauthorized deletions occurred, a definitive answer the default-enabled Activity Log could provide immediately without needing any prior, dedicated forensic logging configuration to have been set up in advance.

4.5 NSG Flow Logs & VNet Flow Logs

NSG Flow Logs (the older mechanism) and VNet Flow Logs (the newer, recommended replacement that operates at the VNet level rather than per-NSG, with improved performance and simpler management) capture IP traffic metadata — the direct analog to AWS VPC Flow Logs, with the same fundamental capability and the same fundamental limitation: metadata only, no packet payload visibility.

- VNet Flow Logs are Microsoft's currently recommended approach over the older NSG Flow Logs, since they capture traffic at the virtual network level (covering traffic NSG Flow Logs might miss depending on exactly where NSGs are or aren't applied) with better processing performance — new flow logging deployments should default to VNet Flow Logs rather than the legacy NSG-scoped mechanism.
- Flow logs feed Traffic Analytics (a Network Watcher capability providing visualized, enriched flow analysis) and are a primary input to Defender for Cloud's network-based recommendations and to Sentinel's network-related analytics rules — playing the same foundational role VPC Flow Logs play for GuardDuty's network-based findings in AWS.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Confirming the absence of unauthorized data egress following a credential exposure incident, mirroring the AWS Flow Logs investigation pattern

Directly mirroring the AWS VPC Flow Logs scenario: following an incident where a service credential was briefly exposed in a misconfigured log statement, a bank's incident response team queries VNet Flow Logs to confirm whether the exposed credential's associated network identity showed any large outbound data transfer to unfamiliar external endpoints during the exposure window — finding none, directly informing the severity classification for the bank's mandatory disclosure assessment.

SAAS / MULTI-TENANT PLATFORM

Traffic Analytics visualizing an unexpected cross-VNet traffic pattern following a hub-spoke peering misconfiguration

A SaaS platform's network team uses Traffic Analytics' visualized flow data to quickly identify that a recently peered spoke VNet was unexpectedly able to reach a different, unrelated spoke VNet directly — tracing the issue to an overly broad peering configuration that hadn't accounted for the hub's intended role as the only transit path between spokes, a misconfiguration the visual traffic-flow representation made immediately obvious in a way that manually reviewing peering configuration JSON would not have.

E-COMMERCE

Establishing a baseline ahead of migrating a newly acquired subsidiary's network onto the shared Sentinel detection pipeline

Mirroring the AWS Flow Logs baseline-establishment scenario: ahead of fully onboarding a newly acquired subsidiary's Azure environment into the parent company's Sentinel-based detection pipeline, the security team enables VNet Flow Logs first and lets them run for several weeks to build a traffic baseline, surfacing an already-existing, undocumented integration with a third-party logistics vendor that needed to be understood and explicitly allow-listed before the broader anomaly-detection rules went live.

4.6 Microsoft Defender for Identity

Defender for Identity is a distinct, identity-specific detection product worth treating separately from the broader Defender for Cloud plans — it monitors on-prem Active Directory domain controllers (via lightweight sensors) and Entra ID signals together, specifically detecting identity-based attack techniques (Kerberoasting, DCSync attacks, lateral movement via stolen credentials, golden ticket attacks) that are largely invisible to cloud-resource-focused detection tools, since these attacks target the identity infrastructure itself rather than a specific cloud resource.

- This is particularly relevant for any organization running a hybrid identity model (on-prem Active Directory synchronized to Entra ID via Entra Connect, common in large enterprises and banks with substantial legacy infrastructure) where a compromise originating on-prem could pivot into cloud resources via the federated identity trust — Defender for Identity is specifically built to catch the on-prem-side attack techniques that precede that kind of pivot, which AWS's detection stack, having no on-prem Active Directory component at all, has no direct equivalent for.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Catching a DCSync attack attempt against an on-prem domain controller before it could be used to pivot into cloud-hosted core-banking resources

A bank running a hybrid identity model with on-prem Active Directory federated to Entra ID has Defender for Identity sensors deployed on its domain controllers, which detect a DCSync attack attempt (a technique used to replicate password hashes from a domain controller, typically a precursor to broader credential compromise) originating from a compromised workstation — flagged and contained before the attacker could leverage any harvested credentials to pivot from the on-prem network into the bank's Entra-ID-federated cloud resources, a detection category specific to on-prem identity infrastructure that no cloud-resource-scoped detection tool would have caught.

SAAS / MULTI-TENANT PLATFORM

Lateral movement detection during an investigation into a compromised developer workstation with on-prem AD access

A SaaS platform retaining a smaller on-prem Active Directory footprint for legacy internal tooling (alongside its primarily cloud-native product infrastructure) uses Defender for Identity to detect lateral movement attempts from a compromised developer workstation toward other on-prem systems using harvested local-admin credentials — confirming the compromise had been contained to a small set of legacy internal systems and hadn't successfully pivoted toward the federated identity trust that would have given it a path toward Entra-ID-protected cloud resources.

E-COMMERCE

Identifying reconnaissance-stage Active Directory enumeration ahead of a planned full migration off on-prem identity infrastructure

An e-commerce company in the process of migrating away from on-prem Active Directory entirely toward a cloud-native Entra-ID-only identity model uses Defender for Identity during the transition period to catch a pattern of unusual LDAP enumeration queries against the remaining on-prem directory — identified as reconnaissance activity from an internal account whose credentials had likely been phished, caught and remediated before the migration project completed and while the legacy on-prem identity infrastructure was still a live attack surface worth actively monitoring.

- Alternatives: this category (identity threat detection and response, ITDR) is increasingly covered by CrowdStrike Falcon Identity Protection and similar EDR-vendor-extended offerings, often run alongside Defender for Identity in larger hybrid environments rather than as a strict replacement.

4.7 Detect Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
Defender for Cloud (Defender plans)	Workload-specific threat detection (Servers, Storage, Key Vault, DNS, APIs)	CrowdStrike/SentinelOne, Sentinel
Microsoft Sentinel	Cloud-native SIEM/SOAR, Fusion correlation, UEBA	Splunk, Chronicle, Logic Apps
Azure Monitor / Log Analytics	Metrics, log queries (KQL), alerting backbone	Resource Graph, Sentinel
Azure Activity Log	Subscription-level control-plane audit trail	Log Analytics, long-term archive
NSG / VNet Flow Logs	Network traffic metadata	Traffic Analytics, Defender for Cloud
Defender for Identity	On-prem AD + Entra ID identity attack detection	CrowdStrike Identity Protection

5. RESPOND

Respond is where most security programs are weakest in practice, not because the Azure services are immature, but because building the orchestration logic connecting detection to action is genuine engineering work that's easy to defer in favor of more visible feature work. Azure's response stack is more natively unified than AWS's — Sentinel playbooks are Logic Apps workflows directly, meaning there's less architectural distance between the SIEM and the automation engine than the AWS EventBridge-to-Lambda-via-separate-services model requires.

5.1 Microsoft Sentinel Playbooks & Azure Logic Apps

Logic Apps is Azure's managed workflow orchestration service — the role EventBridge plus Lambda plus Step Functions collectively play in the AWS architecture, but unified into one visual, connector-based workflow designer. A Sentinel playbook is simply a Logic Apps workflow with a Sentinel-specific trigger (fired automatically when an incident is created or updated), meaning anything Logic Apps can do — and its connector library spans hundreds of Microsoft and third-party services — is available as a response action without separate integration engineering.

Mechanism

- Automation rules in Sentinel provide a lighter-weight layer above full playbooks — simple, no-code conditions and actions (auto-close a specific noisy alert type, auto-assign an incident to a specific analyst based on its source) that don't require building a full Logic Apps workflow for straightforward, common triage logic.
- Playbooks triggered from an incident have access to the full incident context (entities, alerts, severity) and can call out to any connected system — Tines, ServiceNow, Microsoft Teams, or directly to Azure Resource Manager APIs for remediation actions like disabling a user or isolating a VM.
- The same wait-for-approval pattern described for AWS Step Functions exists natively in Logic Apps via an approval connector (e.g., posting an adaptive card to Teams with Approve/Deny buttons) that pauses the workflow until a human responds — built into the same tool running the rest of the automation, rather than a separate orchestration service.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Automation rule auto-escalating any incident tagged against a cardholder-data-environment subscription

A bank configures a Sentinel automation rule that automatically elevates the severity and reassigns to a dedicated PCI-scope analyst queue any incident where the affected resource's subscription is tagged scope:pci, regardless of the incident's original calculated severity — ensuring findings in regulated-scope subscriptions never sit in the general triage queue behind unrelated lower-priority findings, mirroring the same priority-routing rationale described for the AWS EventBridge pattern.

SAAS / MULTI-TENANT PLATFORM

Teams-based approval playbook gating a tenant-data-export deletion action behind human confirmation

Mirroring the AWS Step Functions wait-for-callback scenario: a SaaS platform's Logic Apps playbook for a suspected malicious data-export attempt posts an adaptive card with the relevant evidence to a Microsoft Teams security channel and pauses, waiting for a security engineer to click Approve before the workflow proceeds to revoke the export and notify the tenant's admin — a deliberate human-in-the-loop gate for an action carrying real false-positive risk and customer-facing impact, built using Logic Apps' native approval connector rather than a separate orchestration tool.

E-COMMERCE

Direct Azure Resource Manager API call from a playbook isolating a compromised VM without any custom remediation code

An e-commerce platform's playbook for a Defender for Servers malware finding calls the Azure Resource Manager connector directly from within the Logic Apps workflow to swap the affected VM's NSG association to an isolated, no-egress NSG and detach it from its availability set — accomplished using Logic Apps' built-in Azure Resource Manager connector rather than requiring a custom Azure Function specifically written for this one remediation action, reducing the engineering lift compared to writing equivalent custom Lambda code in the AWS pattern.

Real-world implementation note

The Sentinel-and-Logic-Apps-native pipeline can absolutely be the entire response architecture for an Azure-primary organization, but for any organization also running AWS or third-party tools (Okta, CrowdStrike, ArmorCode) alongside Azure, the same Tines-centric multi-source orchestration pattern described in the AWS document still applies — Sentinel and Logic Apps become one detection source and one set of native remediation actions feeding into the same central Tines pipeline, rather than Azure-side response logic running entirely separately from AWS-side response logic.

5.2 Azure Functions — Automated Remediation

Azure Functions is the equivalent compute layer to AWS Lambda for remediation logic too complex or too custom for a no-code Logic Apps connector action to express directly — typically invoked from within a Logic Apps/Sentinel playbook for the specific step needing custom code, rather than functioning as the primary orchestration layer the way Lambda often does in AWS architectures.

- The same design discipline applies as described for AWS Lambda remediation: every destructive or access-revoking action should have a dry-run mode, independent audit logging, and a defined rollback path, and the same graduated-automation philosophy (full automation for high-confidence/low-blast-radius actions, human approval gates for anything touching production data or customer-facing availability) should govern which actions are fully autonomous versus approval-gated.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Custom Azure Function disabling a leaked credential matched against a high-confidence secret-scanning pattern

Mirroring the AWS Lambda leaked-credential scenario: a bank's GitHub secret-scanning integration flags an Azure service principal credential accidentally committed to a public repository fork. The finding triggers a Logic Apps playbook that calls a custom Azure Function specifically written to disable that one service principal's credential (rather than the broader app registration, to avoid disrupting other potentially legitimate uses) — a high-confidence, low-blast-radius, easily reversible action appropriate for full automation given the urgency of a publicly exposed credential.

SAAS / MULTI-TENANT PLATFORM

Tag-aware remediation function behaving differently for production versus sandbox subscriptions

Mirroring the AWS tag-aware Lambda scenario: a SaaS platform's Azure Function for remediating overly permissive NSG rules checks the subscription's environment tag before acting — auto-remediating immediately in sandbox/dev subscriptions while routing production-subscription findings through the Teams approval playbook instead, reflecting the same deliberate, blast-radius-dependent automation posture described for the AWS pattern, implemented on Azure's equivalent primitives.

E-COMMERCE

Quarantine function detaching a compromised VM from its scale set while preserving it for forensics

Mirroring the AWS autoscaling-group quarantine scenario: following a Defender for Servers malware finding on one VM in the order-processing Virtual Machine Scale Set, an Azure Function automatically removes that specific instance from the scale set (so the scale set's own health-based instance replacement logic doesn't terminate it and destroy forensic evidence) and applies an isolated NSG, while the scale set itself provisions a replacement instance to maintain capacity — containing the incident with no customer-facing checkout impact.

5.3 Microsoft Defender for Cloud — Automated Response Actions

Beyond Sentinel-driven playbooks, Defender for Cloud itself supports workflow automation directly on its own recommendations and alerts — configuring a Logic Apps playbook to trigger automatically whenever a specific Defender for Cloud recommendation or alert is generated, without necessarily routing through a full Sentinel incident first. This is a useful, lighter-weight option for organizations using Defender for Cloud's native alerting without having (or needing) a full Sentinel deployment.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Auto-remediation triggered directly from a Defender for Cloud recommendation, without a Sentinel incident in the loop

A smaller bank subsidiary, running Defender for Cloud but not (yet) a full Sentinel deployment, configures a workflow automation directly on the recommendation 'Storage accounts should restrict network access' so any storage account drifting into public-access-enabled state triggers an immediate remediation playbook reverting the setting — a simpler, lighter-weight response path appropriate for an organization not yet operating a full SIEM/SOAR program but still wanting automated guardrail enforcement on its highest-priority recommendations.

SAAS / MULTI-TENANT PLATFORM

Direct alert-triggered notification routing for Defender for Storage malware findings ahead of full Sentinel correlation

A SaaS platform configures a Defender for Cloud workflow automation on Defender for Storage malware alerts specifically to post an immediate, high-visibility Teams notification the moment a malware finding fires — a faster, more direct path than waiting for the finding to flow through to a Sentinel incident and the standard incident-aggregation timing, appropriate given how unambiguous and high-confidence this specific alert category is.

E-COMMERCE

Workflow automation auto-assigning newly-created high-severity recommendations to the owning team's queue

An e-commerce company configures Defender for Cloud workflow automation to automatically create a ticket in the owning engineering team's queue (identified via the resource's tag-based ownership metadata) whenever a new high-severity recommendation appears against that team's resources — distributing remediation ownership directly to the teams who can actually fix the underlying configuration, rather than centralizing every recommendation into one undifferentiated central security backlog.

5.4 Azure WAF & Azure Firewall — Active Response

Both services, introduced under Protect, have a direct response-time use beyond their standing baseline configuration, mirroring the active-response role described for AWS WAF and Network Firewall.

- **WAF custom rules and IP-based blocking:** during an active incident, a Logic Apps-driven update to a WAF custom rule's IP match condition is the fastest available containment action at the edge — propagating

across Front Door's global edge network within roughly a minute for global incidents, or applied regionally and immediately for an Application Gateway-scoped incident.

- **Azure Firewall rule updates via Firewall Manager:** for an active outbound C2/exfiltration concern, updating a Firewall Manager-distributed policy's FQDN deny list centrally immediately cuts off that path across every Azure Firewall instance the policy applies to, mirroring the centralized Network Firewall domain-block pattern described for AWS.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Emergency Front Door WAF custom rule blocking a confirmed targeted attack source during an active incident

Mirroring the AWS emergency WAF IP-set scenario: upon confirming a targeted, sustained attack from a specific set of source IPs against the online-banking login endpoint, the bank's security team pushes an emergency Logic Apps-driven update to a Front Door WAF custom rule blocking the confirmed-malicious IPs across the global edge within about a minute — faster than any infrastructure-level network change could propagate, without needing a full change-management cycle given the active-incident context.

SAAS / MULTI-TENANT PLATFORM

Centralized Firewall Manager policy update cutting off C2 traffic across every spoke VNet simultaneously

Mirroring the AWS centralized Network Firewall domain-block scenario: upon confirming a specific domain as malware command-and-control infrastructure during an active investigation, a SaaS platform's security team updates the Firewall Manager-distributed policy's FQDN deny list once, centrally — immediately cutting off that outbound path for every spoke VNet across the hub-and-spoke architecture simultaneously, rather than updating each VNet's Azure Firewall instance individually.

E-COMMERCE

Temporary aggressive rate-limiting via WAF custom rule during a confirmed inventory-scalping bot surge

Mirroring the AWS temporary aggressive-rate-limiting scenario: during a confirmed, active scalping-bot surge against a limited product drop beyond what the standing Bot Manager rules were catching, the e-commerce platform's on-call engineer pushes a temporary, more aggressive custom rate-limiting rule scoped specifically to the product and checkout paths for the remainder of the drop window, rolled back automatically via a scheduled Logic Apps workflow once the window closes.

5.5 The Multi-Source Detection & Remediation Pipeline Pattern — Azure Variant

Tying this section together, mirroring the AWS architecture's closing pattern but reflecting Azure's more natively unified detection-and-response stack:

1. Detection sources (Defender for Cloud, Sentinel analytics rules, Entra ID Protection risk signals, third-party tools like CrowdStrike or ArmorCode) generate Sentinel incidents — natively for Azure-native sources via built-in connectors, via API/webhook connectors for third-party sources.
2. Sentinel automation rules apply lightweight, no-code triage logic immediately on incident creation — auto-closing known-noisy patterns, auto-assigning by resource tag, auto-elevating severity for regulated-scope resources.
3. For anything needing fuller logic, a Sentinel playbook (a Logic Apps workflow) fires, with enrichment steps (resource owner lookup, tenant/tag context, prior-incident history) pulling in the same kind of business context the AWS Tines pipeline's enrichment stories provide.
4. Playbook decision logic routes based on confidence and blast radius: high-confidence/low-risk triggers automated remediation via a Logic Apps connector action or a called Azure Function; ambiguous or high-blast-radius cases route to a Teams approval card before any action fires.

5. Every action and decision is logged back to the Sentinel incident's timeline automatically, and a feedback loop (incident closure reason, false-positive tagging) feeds back into tuning analytics rules and playbook logic over time — the same closing-the-loop discipline described for the AWS pattern, native to Sentinel's incident model rather than requiring a separate case-management integration to achieve it.

5.6 Respond Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
Sentinel Playbooks / Logic Apps	Native SOAR automation, approval gates, connector ecosystem	Tines (multi-cloud orchestration layer)
Azure Functions	Custom remediation execution code	Logic Apps connector actions
Defender for Cloud workflow automation	Lighter-weight automation directly on recommendations/alerts	Sentinel playbooks
Azure WAF (custom rules)	Real-time blocking during active incidents	Cloudflare WAF
Azure Firewall / Firewall Manager	Centralized egress containment	Palo Alto/Fortinet appliances

6. RECOVER

Recover is frequently treated as a pure infrastructure/SRE concern separate from security, which is a mistake specifically in the ransomware and destructive-attack threat model — recovery controls are themselves security controls, and a security architecture review that stops at Protect/Detect/Respond without validating Recover capability is reviewing only half the actual risk, exactly as emphasized in the AWS treatment of this function.

6.1 Azure Backup

Azure Backup is the centralized, policy-driven backup service spanning VMs, Azure Files, SQL/SAP HANA databases on VMs, and Azure Database for PostgreSQL/MySQL — the direct analog to AWS Backup, with the Recovery Services vault as the equivalent organizing construct to an AWS Backup vault.

Mechanism

- Backup policies define schedule and retention, assigned to resources within a Recovery Services vault — and, mirroring AWS Backup Policies at the Organizations level, can be enforced org-wide via Azure Policy DeployIfNotExists, ensuring new resources matching a defined scope are automatically enrolled in backup protection rather than depending on each resource owner to configure it manually.
- **Immutability and soft delete:** the control that matters most for ransomware resilience — a Recovery Services vault can be configured with soft delete (recoverable for a retention period even after deletion) and, more strongly, immutability (the vault's backup data cannot be deleted before the configured retention period, with an option to make this immutability setting itself permanently irreversible) — the direct analog to AWS Backup Vault Lock's compliance mode.
- Cross-region restore and cross-subscription/cross-tenant backup: backups can be configured to restore into a different region for disaster recovery purposes, and — critically for the same isolation rationale described in the AWS document — a vault in a separate, dedicated subscription (ideally with separate RBAC and ideally with Multi-User Authorization enabled, requiring a second approver for critical operations like disabling soft delete) provides the same kind of blast-radius isolation as AWS's dedicated backup account pattern.
- **Multi-User Authorization (MUA):** requires a second, independent approval (via Azure Resource Guard, ideally owned by a different team or subscription than the one being protected) before critical vault operations — disabling soft delete, reducing retention, or deleting backup data — can be performed, even by an Owner-level administrator on the vault's own subscription. This is a meaningfully stronger control than relying purely on RBAC restriction, since it specifically defends against a single compromised or rogue administrative identity, even one with apparently full rights, acting alone.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Multi-User Authorization preventing a single compromised administrative identity from disabling backup immutability

A bank configures Multi-User Authorization on its core-banking Recovery Services vault, with the Resource Guard specifically owned by a separate security subscription that the core-banking infrastructure team has no administrative access to — meaning even a fully compromised core-banking subscription administrator identity, with apparently complete control over that subscription, cannot unilaterally disable backup immutability or delete backup data, since doing so requires approval from the separately-controlled Resource Guard, directly defeating the ransomware scenario where an attacker who has escalated to full administrative control attempts to destroy backups before triggering the actual encryption/destruction payload.

SAAS / MULTI-TENANT PLATFORM

Tabletop ransomware exercise validating that a compromised production subscription still leaves backups recoverable

Mirroring the AWS cross-account backup tabletop scenario: a SaaS platform's tabletop ransomware exercise specifically models a scenario where the attacker gains broad administrative access to the production subscription itself — the exercise confirms that because backups are configured with immutability in a separate, dedicated backup subscription with Multi-User Authorization protecting the vault, even this worst-case compromise scenario leaves the backup copies untouched and the platform recoverable.

E-COMMERCE

Azure Policy-enforced backup policy assignment catching a newly provisioned database that had been missed

An e-commerce company's Azure Policy DeployIfNotExists assignment, enforcing automatic enrollment of any new production-tagged Azure Database for PostgreSQL instance into the standard backup policy, catches and auto-remediates a newly provisioned database that a developer had created directly via the Azure CLI during a rushed feature deployment, bypassing the team's usual Terraform-based provisioning path that would normally have included backup configuration as part of the module — closing the gap automatically rather than depending on someone noticing the manually-created resource lacked backup coverage.

Real-world implementation note

The architecture pattern that matters most here, directly mirroring the AWS guidance: a dedicated backup subscription, separate from workload subscriptions, with Multi-User Authorization protecting the vault's critical operations. If a single subscription's compromise — even with apparent full administrative control — can also reach and delete backups, the backup strategy has not achieved real isolation regardless of how frequently backups run.

Alternatives

Veeam, Druva, and Rubrik remain the common third-party alternatives, for the same unified multi-cloud/on-prem backup management and more advanced ransomware-specific anomaly detection reasons described in the AWS document.

6.2 Storage Redundancy, Soft Delete & Immutable Blob Storage

Beyond Azure Backup's vault-based model, Azure Storage has its own native redundancy and recovery capabilities worth treating separately, mirroring the dedicated treatment given to S3 Versioning and Object Lock in the AWS document's Recover section.

Redundancy options (LRS, ZRS, GRS, GZRS)	Locally redundant (three copies in one datacenter), zone-redundant (across availability zones in one region), geo-redundant (replicated to a paired secondary region), and geo-zone-redundant (both) — a pure availability/durability decision distinct from immutability, but a prerequisite layer underneath any recovery strategy, since the recovery point itself has to survive a localized failure for any of the higher-level immutability controls to matter.
Blob soft delete	Retains deleted blobs in a recoverable state for a configured retention period — protects against accidental or malicious deletion the same way S3 Versioning protects against accidental overwrite, but does not on its own prevent a sufficiently privileged identity from permanently purging the soft-deleted data before the retention period via a separate explicit action.
Immutable blob storage (time-based retention & legal hold)	Covered under Protect (Section 3.14) for its data-protection role; the recovery-specific framing matters because this is the control that actually guarantees

	recoverability against a privileged-identity-driven destructive attack, the same role Object Lock compliance mode plays in the AWS document.
Point-in-time restore for blob storage	For storage accounts with blob versioning and change feed enabled, point-in-time restore can revert an entire container (or the account) to a specific prior state within the retention window — a faster, more surgical recovery option than restoring from a full Azure Backup vault recovery point for blob-specific incidents.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Geo-zone-redundant storage combined with immutability satisfying both an availability and a destruction-resistance regulatory requirement simultaneously

A bank's regulatory-archive storage account uses geo-zone-redundant storage (surviving both a zone-level and a full-region failure) combined with time-based immutability — satisfying the regulator's availability expectation (data survives infrastructure failure) and destruction-resistance expectation (data cannot be deleted by any identity, including during the retention period, even in the secondary region) as two independent, simultaneously-required properties of the same storage configuration.

SAAS / MULTI-TENANT PLATFORM

Point-in-time restore reverting a container after a customer-facing data-corruption bug, faster than a full vault restore

Following a bug in a data-migration script that corrupted a subset of objects in a customer-facing assets container, a SaaS platform uses blob storage's point-in-time restore capability (having had versioning and change feed enabled in advance specifically to support this recovery path) to revert the affected container to its state immediately before the migration script ran — a faster, more surgical recovery than restoring the entire storage account from the most recent Azure Backup vault recovery point, which would have also reverted unrelated, legitimate changes made to other containers in the same account since the last backup.

E-COMMERCE

Soft delete catching an accidental bulk-delete during a catalog migration, mirroring the AWS S3 Versioning scenario

Mirroring the AWS S3 Versioning catalog-migration scenario: during a large product-catalog data migration, a script intended to delete only deprecated test records instead matched and deleted a broader set of live catalog images due to a filter logic error. Because the storage account had soft delete enabled, every deleted blob remained recoverable within the retention window, and the team restored the affected objects within the hour — without soft delete, this would have required a full restore from the previous night's backup and lost any same-day catalog updates.

6.3 Azure Site Recovery

Azure Site Recovery (ASR) provides continuous, near-real-time replication of on-prem or Azure VMs into a target region, with orchestrated, automated failover — the direct analog to AWS Elastic Disaster Recovery, with a comparable mechanism and cost profile, and the same fundamentally different positioning from backup (continuous replication for fast failover, rather than periodic snapshots for point-in-time restore).

- **Mechanism:** a lightweight Mobility service agent replicates disk changes continuously to the target region; failover orchestration (via Recovery Plans, which sequence multi-VM, multi-tier application failover including pre/post scripts and manual approval checkpoints) automates what would otherwise be a complex, error-prone manual multi-system failover sequence.
- **Relationship to Key Vault:** directly mirroring the AWS DRS-and-KMS-Multi-Region-Keys relationship, any ASR-replicated VM using disk encryption with a Key Vault-housed customer-managed key needs that key (or an appropriately replicated/accessible equivalent) available in the target recovery region, or the

replicated disk data will be unreadable during an actual failover — a dependency that must be explicitly validated during DR testing, not assumed.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Recovery Plan orchestrating a regulator-mandated sub-hour core-banking failover across multiple dependent VM tiers

Mirroring the AWS DRS regulatory RTO scenario: a bank's regulator mandates a maximum recovery time objective of under one hour for core-banking transaction processing. An Azure Site Recovery Recovery Plan, sequencing the correct startup order across the database tier, application tier, and integration tier (each depending on the previous being healthy before proceeding) with automated health-check gates between stages, lets the bank demonstrate during the mandated annual DR test that a full regional failover completes within the regulatory window — a coordinated, multi-tier sequence that would be extremely error-prone to execute manually under actual incident pressure.

SAAS / MULTI-TENANT PLATFORM

ASR covering a legacy VM-based subsystem that predates the platform's cloud-native multi-region architecture

Mirroring the AWS DRS legacy-monolith scenario: a SaaS platform's newer services are built with native multi-region active-active resilience, but a legacy VM-hosted billing subsystem inherited from an early acquisition isn't yet re-architected for that pattern. Rather than delaying disaster-recovery coverage until the re-architecture project completes, the platform uses Azure Site Recovery specifically for that legacy subsystem as an interim VM-level DR mechanism.

E-COMMERCE

DR game day catching a Key Vault regional-availability gap before it mattered, mirroring the AWS KMS gap scenario

Mirroring the AWS DRS/KMS game-day scenario: during a scheduled DR game-day exercise, an e-commerce company's team discovers that a Key Vault customer-managed key protecting a specific VM's disk encryption was only accessible from the primary region's network configuration, not the recovery region — meaning the ASR-replicated VM, while present in the recovery region, would have failed to boot during an actual failover due to being unable to reach its encryption key. The gap is caught and remediated during the planned exercise rather than during an actual disaster.

6.4 Azure Resource Manager Templates / Bicep — Recovery Angle

Mirroring the CloudFormation/Terraform recovery role described in the AWS document: for any environment defined as infrastructure-as-code via ARM templates or Bicep (Microsoft's more ergonomic, increasingly standard authoring layer that compiles to ARM templates), the fastest and most reliable recovery path for a compromised or corrupted environment is frequently a full redeploy from the last known-good template version in source control, combined with a clean backup restore, rather than attempting to manually audit and reverse changes within a live, potentially still-compromised environment.

- Azure Policy's own remediation tasks (Section 1.2) play the same configuration-state-recovery role described for AWS Config remediation — reverting a drifted, attacker-modified, or accidentally-changed resource configuration back to the policy-defined known-good state automatically.

Real-World Implementation Scenarios

BANKING / FINANCIAL SERVICES

Automated Azure Policy remediation reverting an attacker-modified NSG rule during active incident containment

Mirroring the AWS Config-remediation-during-incident scenario: during an active incident where an attacker briefly gained access sufficient to modify an NSG rule on a sensitive internal service, opening an unintended inbound path, an Azure Policy remediation task monitoring that NSG's expected baseline configuration reverts the deviation automatically within minutes of detecting the drift — closing the unauthorized access path as part of the broader incident response without waiting for a human to manually identify exactly what had changed.

SAAS / MULTI-TENANT PLATFORM

Full environment rebuild from Bicep templates following a suspected supply-chain compromise of a build dependency

Mirroring the AWS IaC-rebuild scenario: following a suspected compromise of a build-time dependency with uncertain scope of impact, a SaaS platform's security team rebuilds the affected service's infrastructure from its Bicep definitions in a fresh subscription, rather than attempting to audit and clean the existing, potentially-compromised environment line by line — a decision only possible because the infrastructure was fully defined in version-controlled IaC with no manually-configured drift.

E-COMMERCE

ARM template redeployment restoring the checkout service after a botched manual portal hotfix

Mirroring the AWS CloudFormation redeployment scenario: an engineer's manual, undocumented hotfix applied directly in the Azure portal during a production incident introduced a subtle misconfiguration not caught until days later. Rather than trying to manually identify and reverse the undocumented change, the team redeploys the affected resource group from the last known-good ARM template version in source control, restoring the service to a known, version-controlled state in minutes.

6.5 Multi-Subscription Recovery Pattern — Summary

Pulling the Recover function together into the architecture pattern that should actually be reviewed and tested, mirroring the AWS document's closing recovery pattern but on Azure's equivalent primitives:

- A dedicated, isolated backup subscription holds Recovery Services vaults with immutability enabled and Multi-User Authorization protecting critical vault operations; workload subscription identities can back up to the vault but cannot independently disable its protections.
- Critical infrastructure is defined in IaC (Bicep or ARM templates) version-controlled outside the Azure environment itself, so a full environment rebuild does not depend on any state stored inside the environment being rebuilt.
- Key Vault keys protecting any data with a defined recovery requirement are accessible from the recovery region (via appropriate replication or an equivalent key-availability plan) so replicated/restored data is actually decryptable during an actual failover.
- Restore and failover procedures are tested on a defined cadence via scheduled DR game-day exercises, with results tracked as a governance metric, not assumed to work because they were configured correctly once.
- The recovery plan explicitly accounts for the scenario where the primary workload subscription itself is fully compromised — meaning the backup subscription and recovery procedures cannot depend entirely on access that originates from the compromised subscription.

6.6 Recover Function — Summary Table

Service	Primary Role	Pairs With / Alternatives
Azure Backup	Centralized backup, immutability, Multi-User Authorization	Veeam, Druva, Rubrik
Storage redundancy / soft delete / immutable blob	Object-level durability, immutability, point-in-time restore	Azure Backup, Purview
Azure Site Recovery	Continuous replication, orchestrated regional failover	Multi-region active-active app architecture
Azure Policy remediation	Automated configuration state recovery	Azure Functions, Logic Apps
ARM Templates / Bicep	Infrastructure rebuild from version-controlled IaC	Terraform (cross-cloud alternative)

Appendix A — Full Service Cross-Reference Matrix

Services that appear under multiple CSF functions are listed once per relevant function, consistent with their treatment in the body of this document. The AWS Equivalent column cross-references the companion AWS Security Services document for readers operating both clouds.

Azure Service	CSF Function(s)	AWS Equivalent
Management Groups & Subscriptions	Govern	Organizations (OUs, Accounts)
Azure Policy & Initiatives	Govern	SCPs + Config + Conformance Packs
Microsoft Purview Compliance Manager	Govern	AWS Artifact (partial)
Entra Permissions Management	Govern, Identify	IAM Access Analyzer + CIEM
Defender for Cloud (CSPM)	Identify, Detect	Security Hub + GuardDuty plans
Defender Vulnerability Management	Identify	Amazon Inspector
Microsoft Purview (data discovery)	Identify	Amazon Macie (broader scope)
Azure Resource Graph	Identify	Resource Explorer / Config aggregator
Microsoft Entra ID	Protect	IAM + IAM Identity Center + Cognito (partial)
Entra Conditional Access	Protect	No single direct equivalent
Entra ID Governance (PIM, Access Reviews)	Protect	IAM Identity Center + Access Analyzer (partial)
Azure Key Vault / Managed HSM	Protect	KMS + Secrets Manager + ACM + CloudHSM
Azure WAF	Protect, Respond	AWS WAF
Azure DDoS Protection	Protect	AWS Shield
Azure Firewall / Firewall Manager	Protect, Respond	AWS Network Firewall + Firewall Manager
NSGs / ASGs / Private Link	Protect	Security Groups/NACLs + PrivateLink
Azure Front Door / CDN	Protect	Amazon CloudFront
Azure DNS / Private DNS	Protect, Detect	Amazon Route 53
Azure Application Gateway	Protect	Application Load Balancer
Azure Bastion	Protect	Systems Manager Session Manager
Defender for Containers / AKS	Protect, Detect	GuardDuty EKS + Inspector ECR
Storage Account security controls	Protect, Recover	S3 security controls
Defender for Cloud (Defender plans)	Detect	GuardDuty protection plans
Microsoft Sentinel	Detect, Respond	Security Hub + SIEM + SOAR

Azure Service	CSF Function(s)	AWS Equivalent
Azure Monitor / Log Analytics	Detect	CloudWatch + CloudTrail Lake
Azure Activity Log	Detect	CloudTrail (management events)
NSG / VNet Flow Logs	Detect	VPC Flow Logs
Defender for Identity	Detect	No single direct equivalent (on-prem AD-aware)
Sentinel Playbooks / Logic Apps	Respond	EventBridge + Lambda + Step Functions
Azure Functions	Respond	AWS Lambda
Azure Backup	Recover	AWS Backup
Storage redundancy / immutable blob	Recover	S3 Versioning / Object Lock
Azure Site Recovery	Recover	AWS Elastic Disaster Recovery
ARM Templates / Bicep	Recover	CloudFormation

Appendix B — Architecture Principles Referenced Throughout

- **1. The tenant root and top-level management groups carry only governance scaffolding, not workloads.** Mirroring the AWS management-account principle: structural scopes exist to apply policy and RBAC consistently, not to host production resources directly.
- **2. No standing high-privilege role assignments for humans.** Workforce privileged access flows through PIM just-in-time activation with Conditional Access requiring phishing-resistant MFA at activation time; workload identity uses managed identities rather than stored credentials wherever possible.
- **3. Detective and posture controls are enabled org-wide by default at subscription creation,** via Azure Policy DeployIfNotExists at the management group level — Defender for Cloud plans, diagnostic settings routing to the central Log Analytics workspace, and backup policy enrollment are baseline, not opt-in per team.
- **4. Every Protect control is evaluated against tenant-isolation failure, not just external-attacker failure.** Azure RBAC conditions, per-tenant Key Vault keys where justified, and tenant claims validated end-to-end from Entra ID token issuance through RBAC enforcement are the mechanisms that make this real.
- **5. Detection signal from every source — Azure-native and third-party — converges on one orchestration layer.** Sentinel and Logic Apps natively unify much of this within Azure; for multi-cloud organizations, the same signal still feeds a broader central pipeline (Tines or equivalent) alongside AWS- and third-party-sourced findings.
- **6. Recovery capability assumes the primary subscription is the thing that failed.** Backups, IaC state, and recovery procedures cannot depend entirely on access or state that originates from the subscription being recovered — Multi-User Authorization on the backup vault is the specific Azure control that enforces this assumption rather than just documenting it.

— End of Document —